

Laboratorio: Port Swigger

21003676

Lab: Username enumeration via different responses

The screenshot shows the Burp Suite interface. The top panel displays a list of HTTP requests. The selected request is a POST to `/login` with a status code of 200. The response is a 200 OK with a content type of `text/html; charset=utf-8`. The response body contains HTML code, including a `<div id="academyLabHeader">` tag. The Inspector panel on the right shows the selected text "user" from the response body.

#	Host	Method	URL	Params	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time
1	https://www.google.com	GET	/warmup.html		404	1782	HTML	html	Error 404 (Not Found)!!		✓	142.251.156.119		12:57:41.15
2	https://0ab700aa04e2cb5a...	GET	/		200	8671	HTML		Username enumerati...		✓	79.125.84.16	session=Qwxhso...	12:57:52.15
18	https://0ab700aa04e2cb5a...	GET	/academyLabHeader		101	147					✓	79.125.84.16		12:57:57.15
20	https://0ab700aa04e2cb5a...	GET	/my-account		302	86					✓	79.125.84.16		12:58:35.15
21	https://0ab700aa04e2cb5a...	GET	/login		200	3267	HTML		Username enumerati...		✓	79.125.84.16		12:58:36.15
27	https://0ab700aa04e2cb5a...	GET	/academyLabHeader		101	147					✓	79.125.84.16		12:58:37.15
28	https://0ab700aa04e2cb5a...	POST	/login		200	3352	HTML		Username enumerati...		✓	79.125.84.16		12:58:45.15
29	https://0ab700aa04e2cb5a...	GET	/academyLabHeader		101	147					✓	79.125.84.16		12:58:48.15

Request

```
https://0ab700aa04e2cb5a8596fe6300ef0057.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0ab700aa04e2cb5a8596fe6300ef0057.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
username=user&password=user
```

Response

```
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 3244
<!DOCTYPE html>
<html>
<!--LAB_HEADER_START-->
<head>
<link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
<link href="/resources/css/labs.css" rel="stylesheet">
<title>
Username enumeration via different responses
</title>
</head>
<!--LAB_HEADER_END-->
<body>
<script src="/resources/labheader/js/labHeader.js">
</script>
<!--LAB_HEADER_START-->
<div id="academyLabHeader">
```

El parámetro de username lo enviamos a Burp Intruder

The screenshot shows the Burp Suite Intruder interface. The top panel displays the attack configuration for the `/login` endpoint. The payload is a list of usernames: `argentina`, `carlos`, `root`, `admin`, `test`, `guest`, `info`, `adm`, `mysql`, `user`, and `administrator`. The selected payload is `argentina`. The bottom panel shows the resulting HTML response, which includes a `<div id="academyLabHeader">` tag. The response body contains HTML code, including a `<div id="academyLabHeader">` tag.

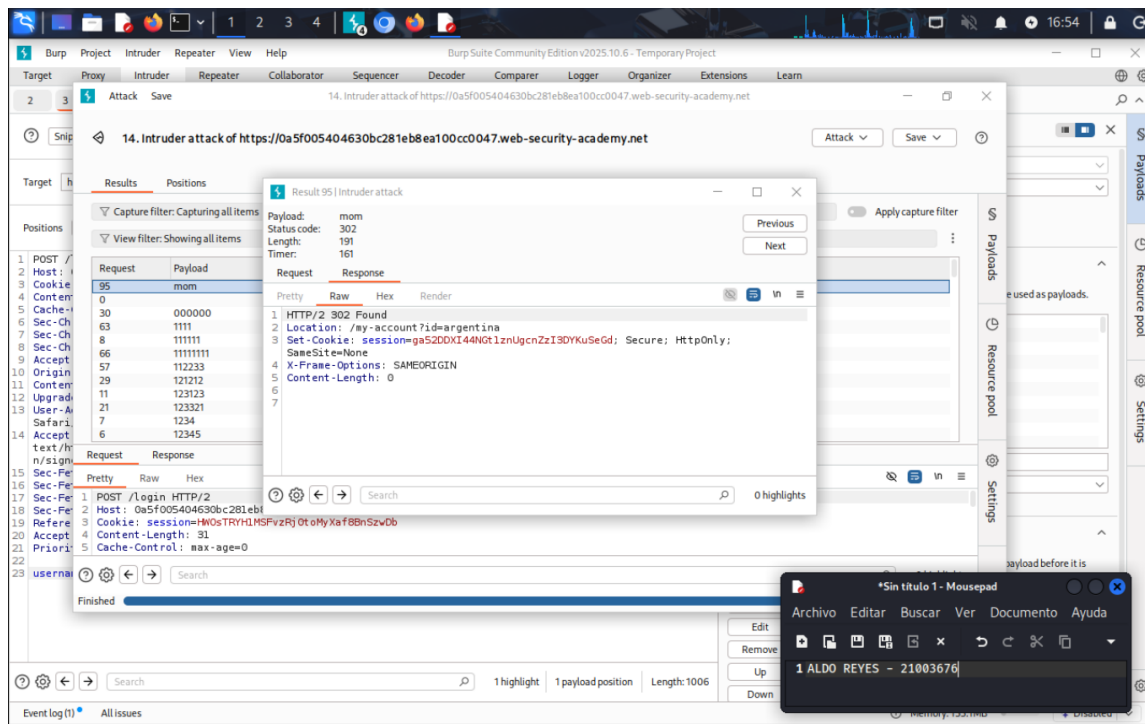
Request

```
POST /login HTTP/2
Host: 0a5f005404630bc281eb8ea100cc047.web-security-academy.net
Cookie: session=H0s3RYHLMSPvzRj01
Content-Length: 32
Cache-Control: max-age=0
Sec-Ch-Ua: "Not A Brand";v="99",
Sec-Ch-Ua-Mobile: 70
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: es-419,es;q=0.9
Origin: https://0a5f005404630bc281eb8ea100cc047.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
```

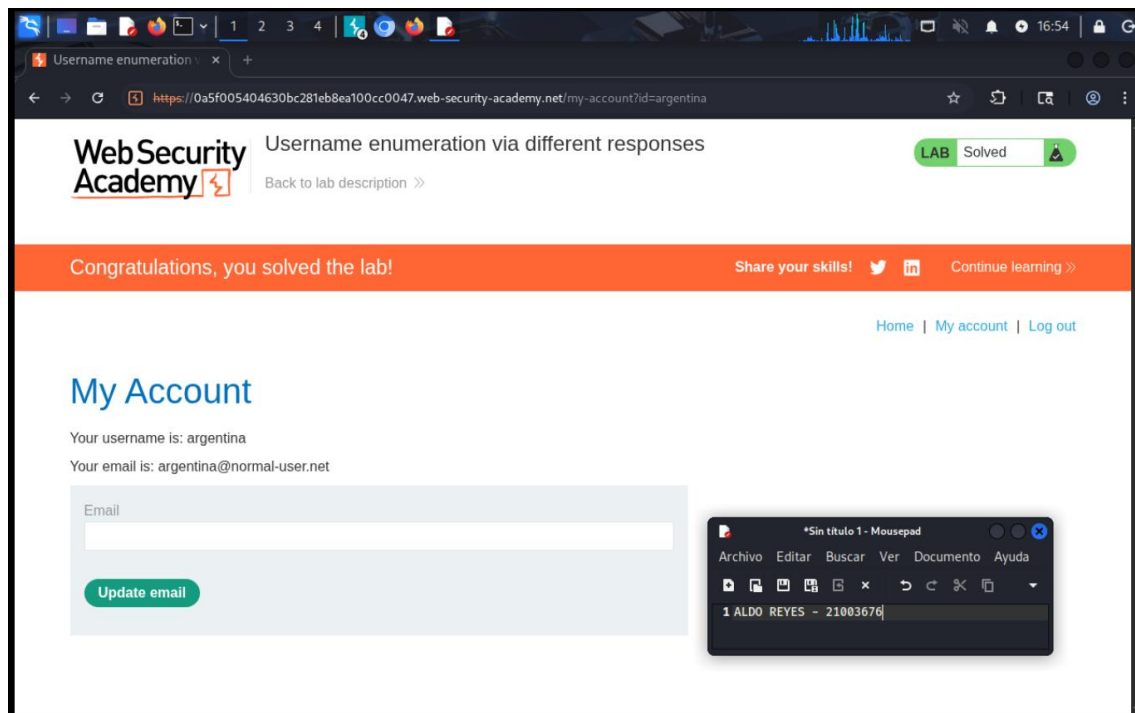
Response

```
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 3244
<!DOCTYPE html>
<html>
<!--LAB_HEADER_START-->
<head>
<link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
<link href="/resources/css/labs.css" rel="stylesheet">
<title>
Username enumeration via different responses
</title>
</head>
<!--LAB_HEADER_END-->
<body>
<script src="/resources/labheader/js/labHeader.js">
</script>
<!--LAB_HEADER_START-->
<div id="academyLabHeader">
```

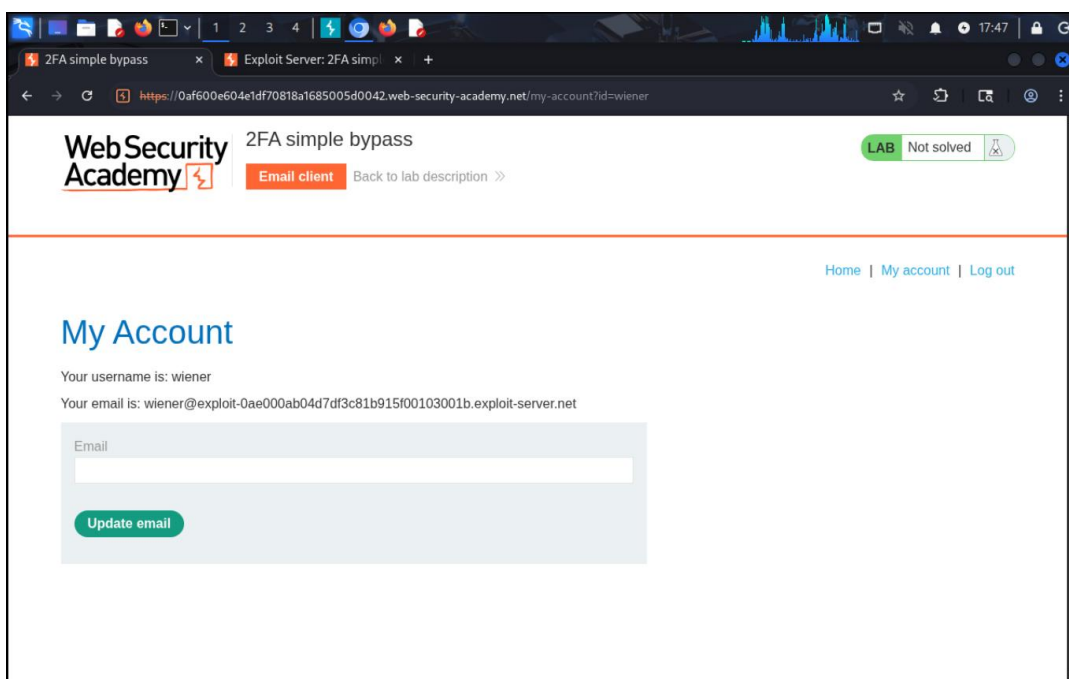
Pegamos una lista de posibles usuarios y hacemos un ataque a la fuerza para averiguar el usuario el cual es “argentina”



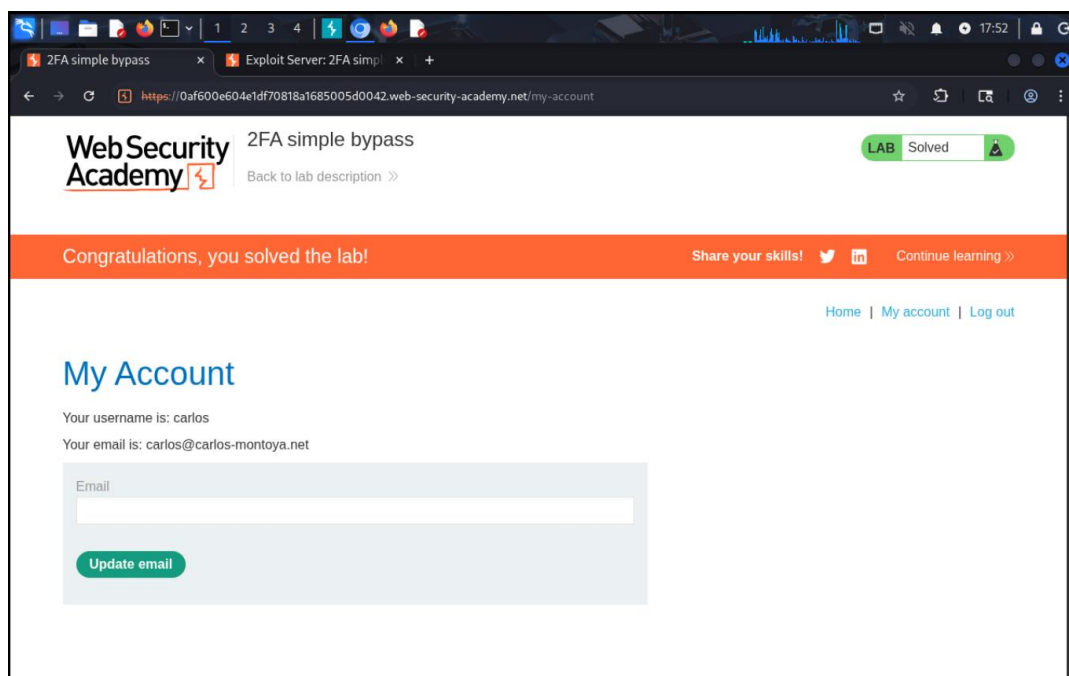
Ahora con otra lista de contraseñas posibles hacemos un nuevo ataque para averiguar la contraseña la cual es “mom”



Lab: 2FA simple bypass



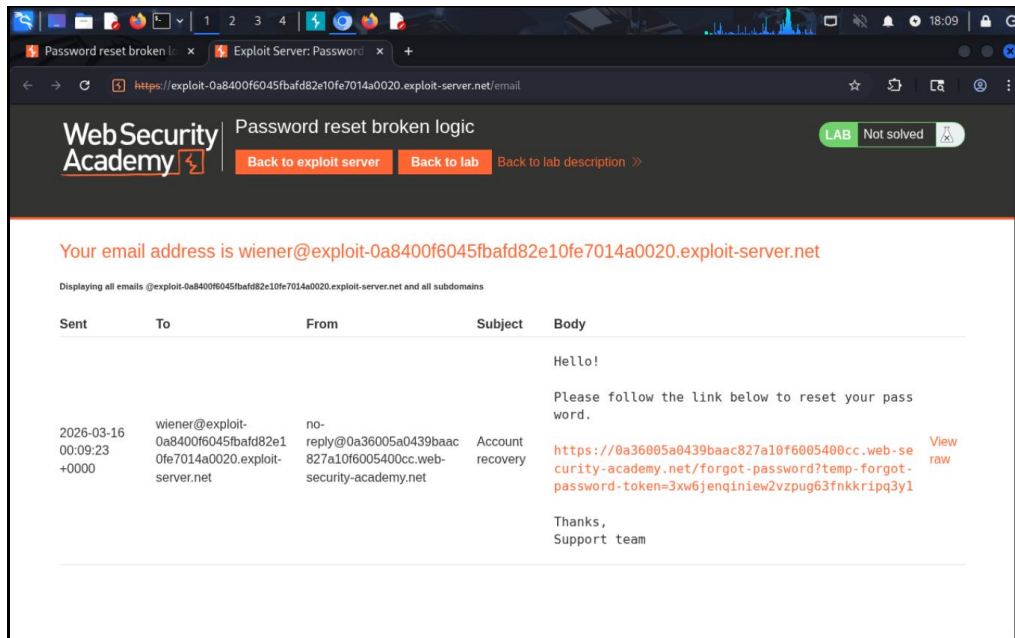
Al ingresar con nuestro usuario Wiener una vez dentro de la cuenta miramos el correo apuntamos la url.



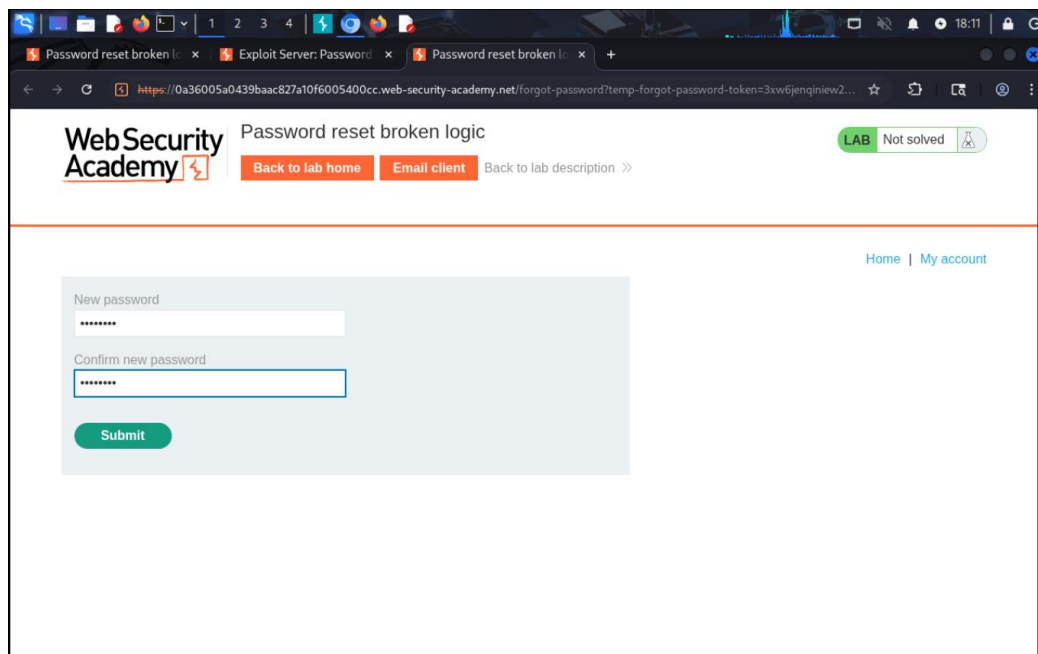
Iniciamos sesión con las credenciales de la víctima al perdimos el código de verificación modificamos la url de la siguiente forma:

https://0af600e604e1df70818a1685005d0042.web-security-academy.net/login2 =>
https://0af600e604e1df70818a1685005d0042.web-security-academy.net/my-account

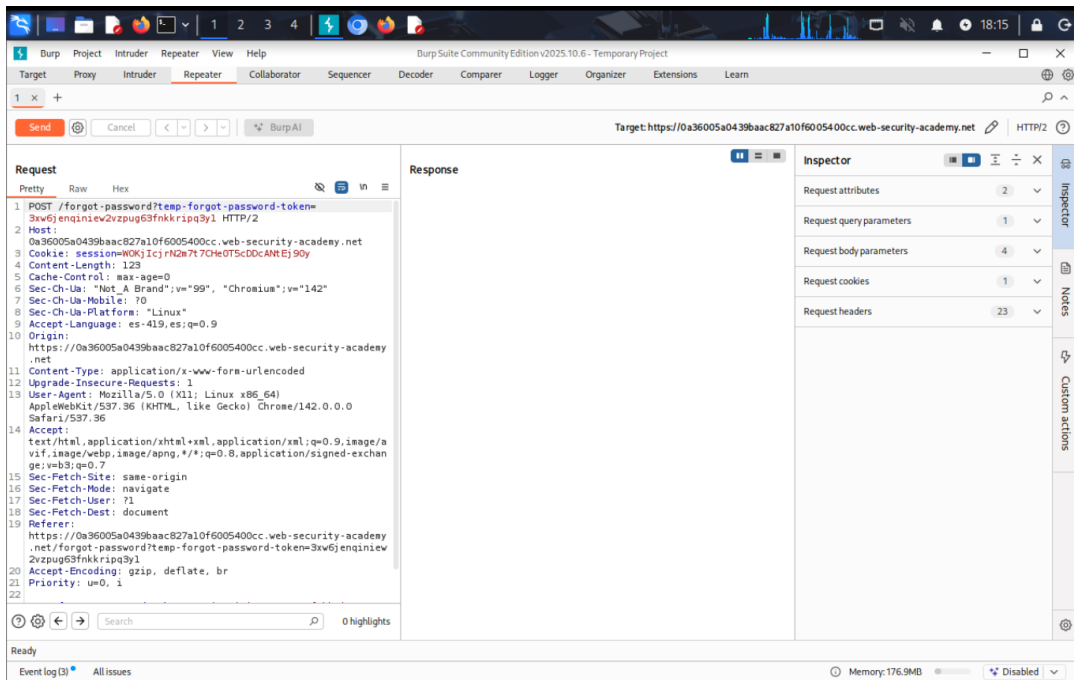
Lab: Password reset broken logic



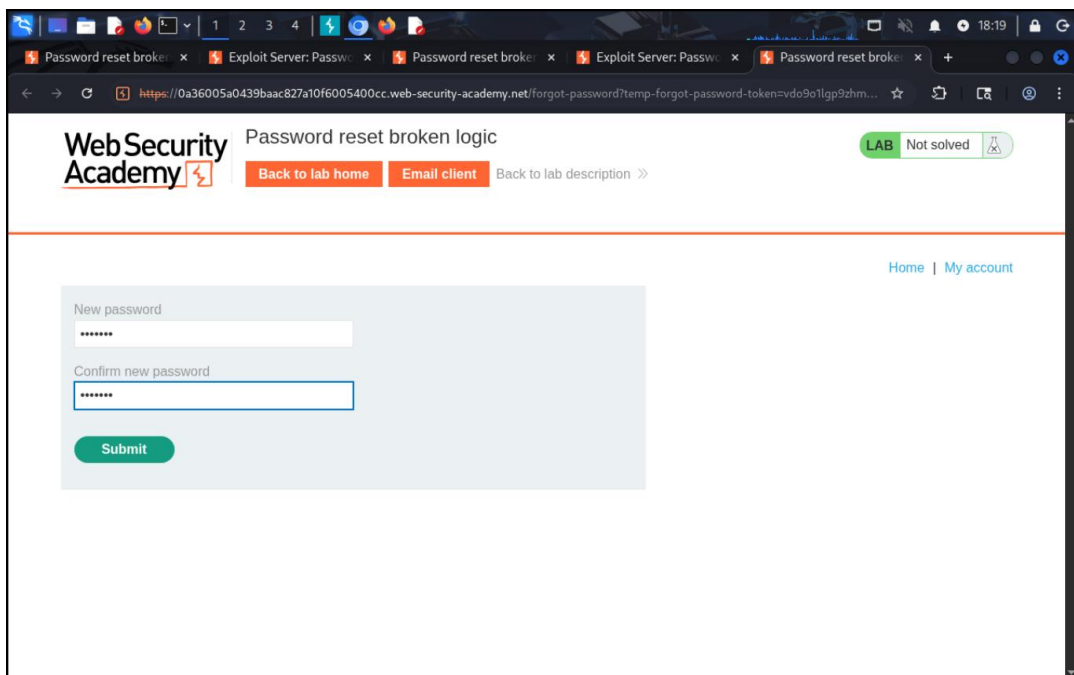
Usando el botón “¿Olvidaste tu contraseña?” nos enviaran un correo para establecerla



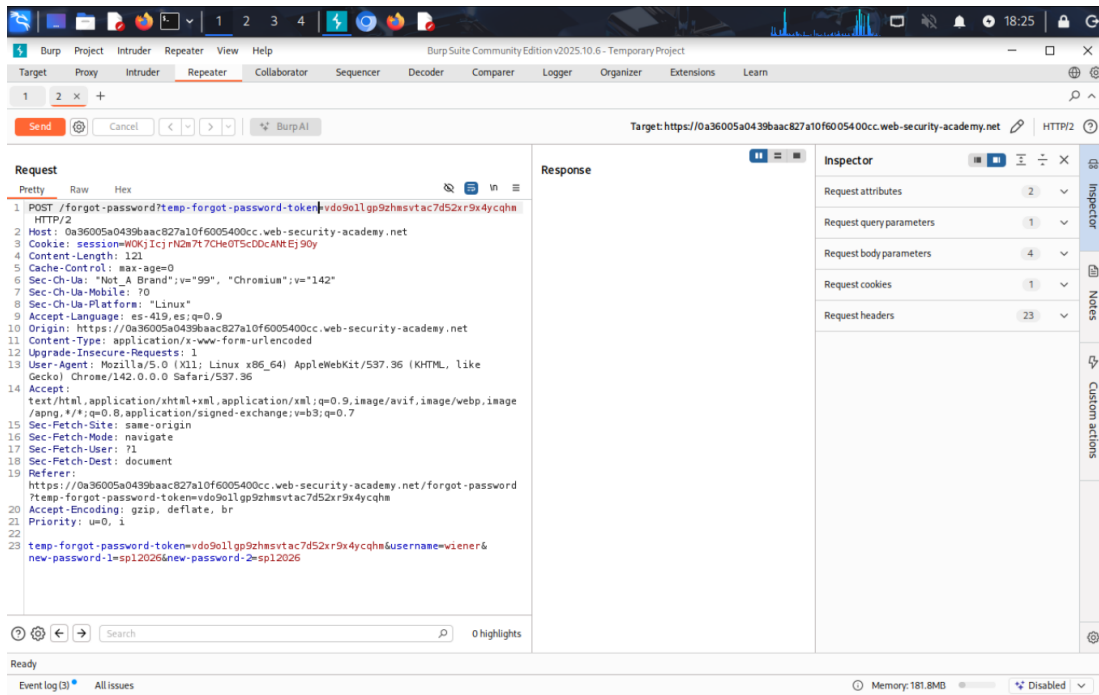
La nueva contraseña es “Admin321”



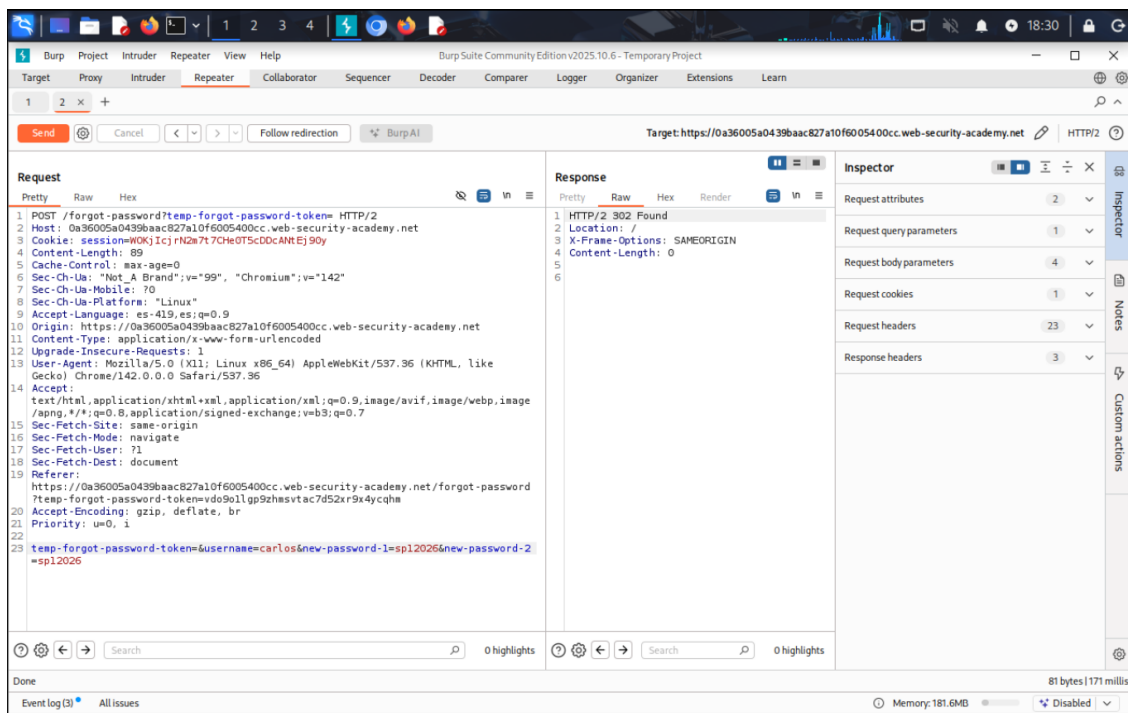
Enviamos “Post/ forgot-password” a Repeater, para enviar una nueva solicitud nueva para cambiar la contraseña ya que el token no se comprueba al enviar la contraseña nueva.



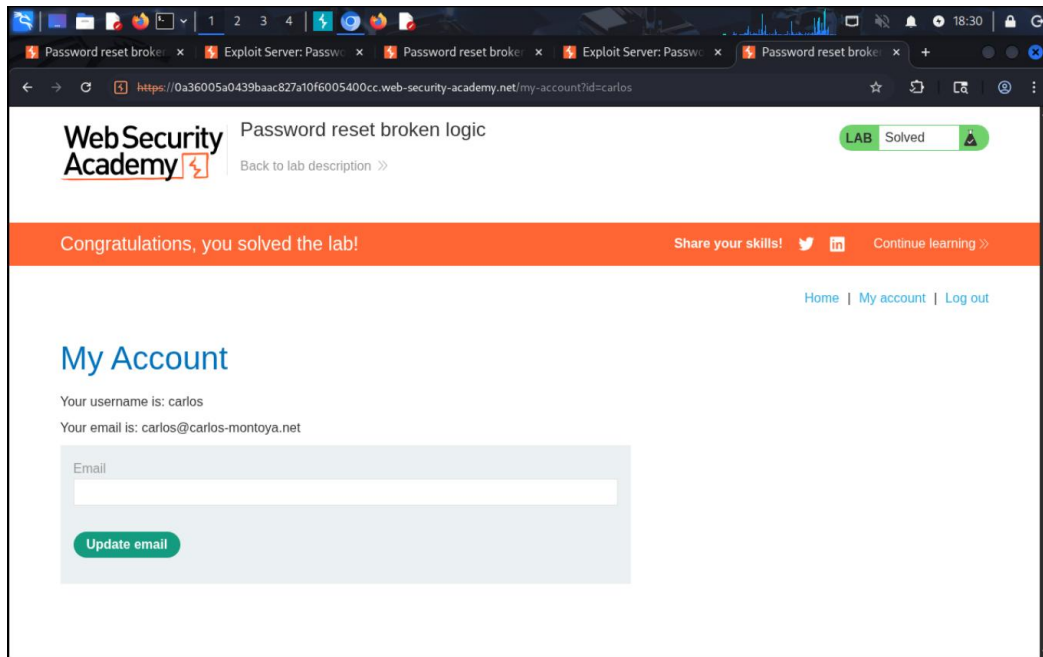
Nueva contraseña "Sp12026"



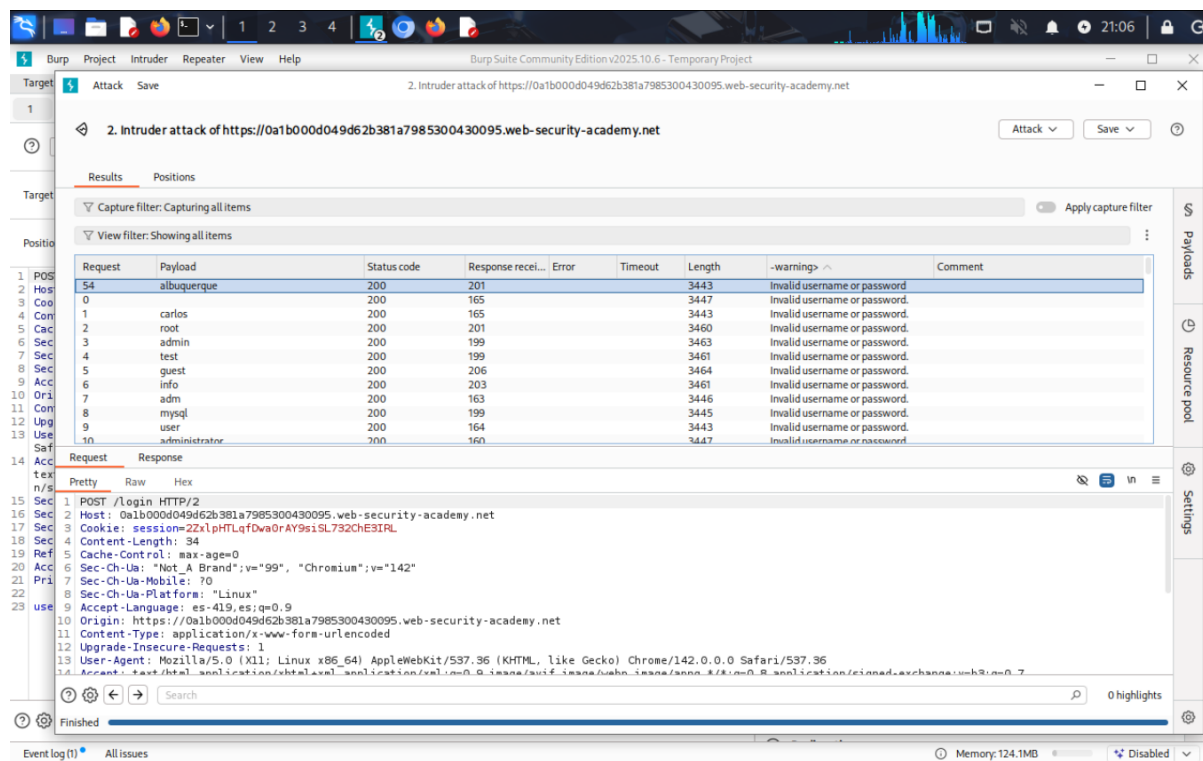
Entramos nuevamente a Repeater



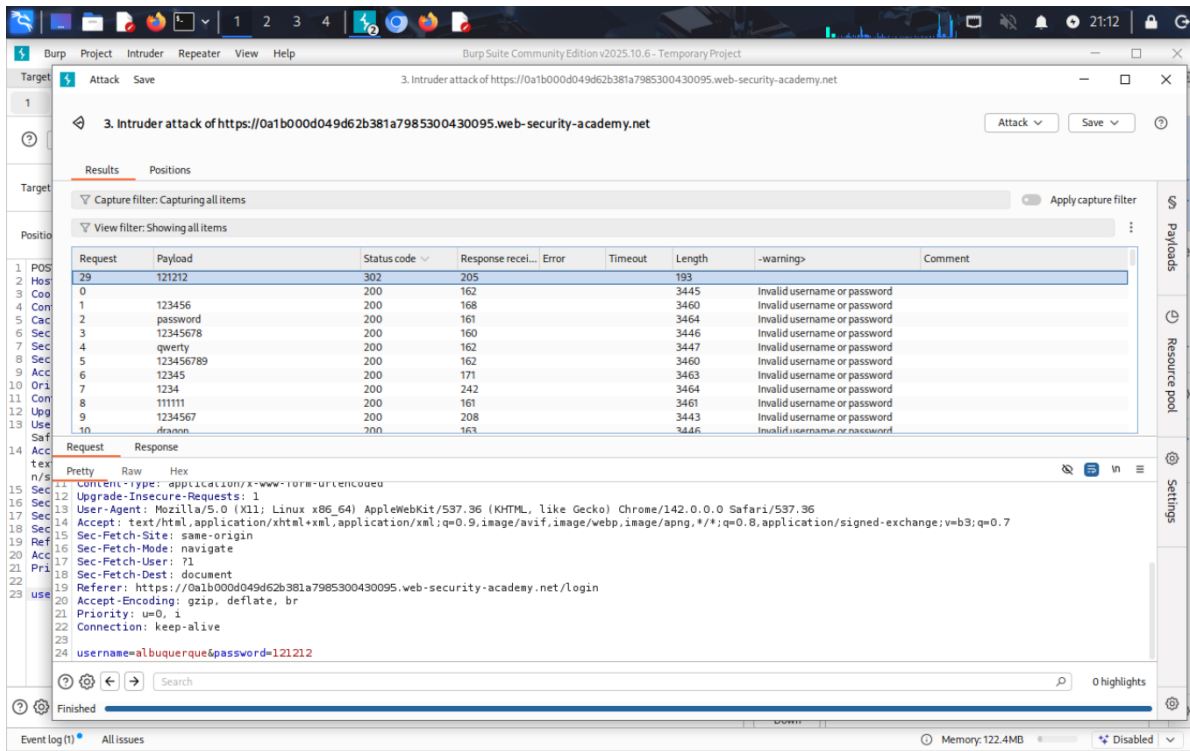
Borramos el valor del paramatreo “temp-forgot-password-token”, enviamos el usuario de Carlos en lugar de Wiener y la contraseña se queda igual, al enviar la solicitud nuevamente iniciamos sesión con:
username: Carlos y password: sp12026



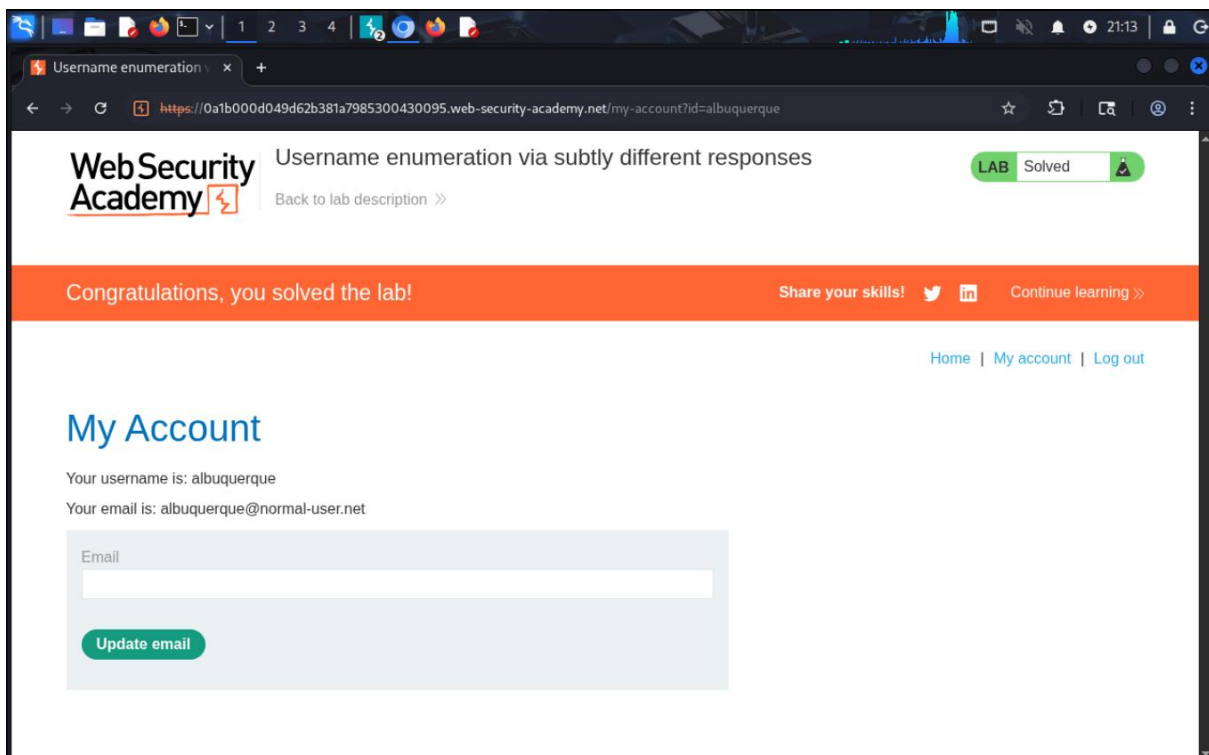
Lab: Username enumeration via subtly different responses



Empezamos haciendo un ataque de fuerza bruta con una lista de usuarios posibles y el usuario sería “albuquerque”

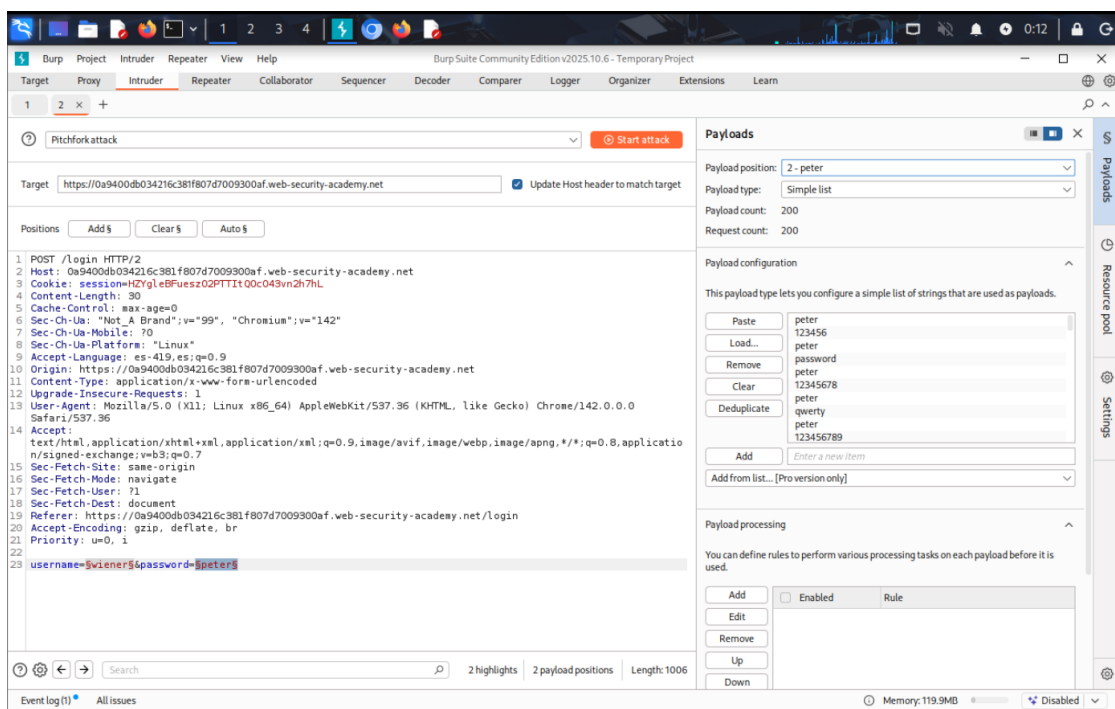
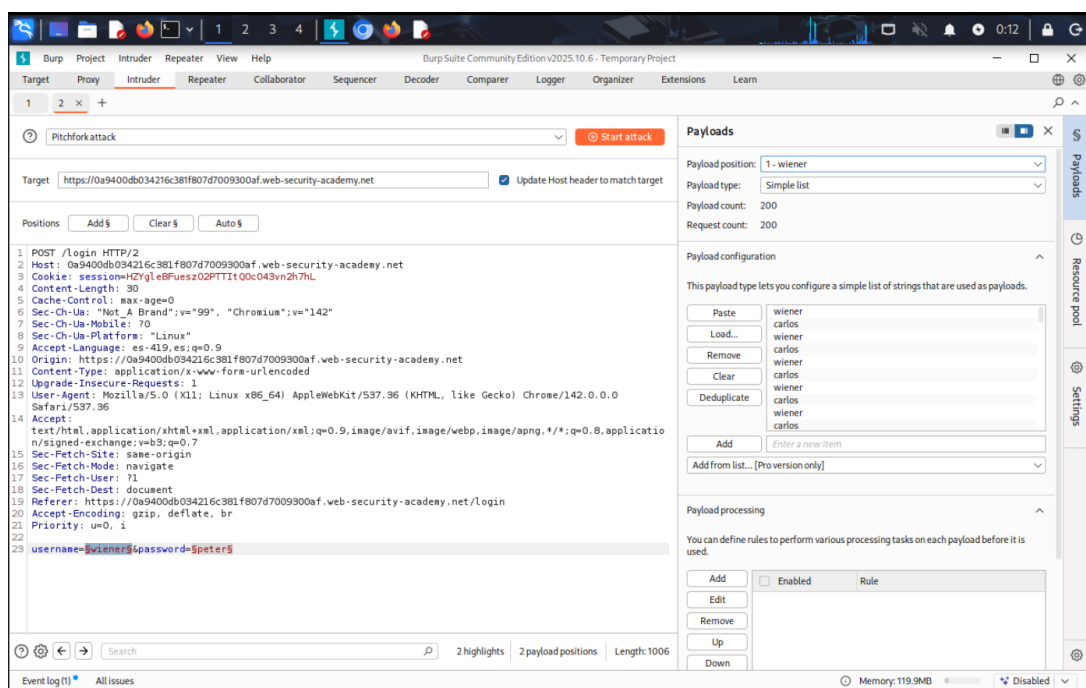


Hacemos lo mismo pero con un listado de contraseñas y la contraseña encontrada sería “121212”

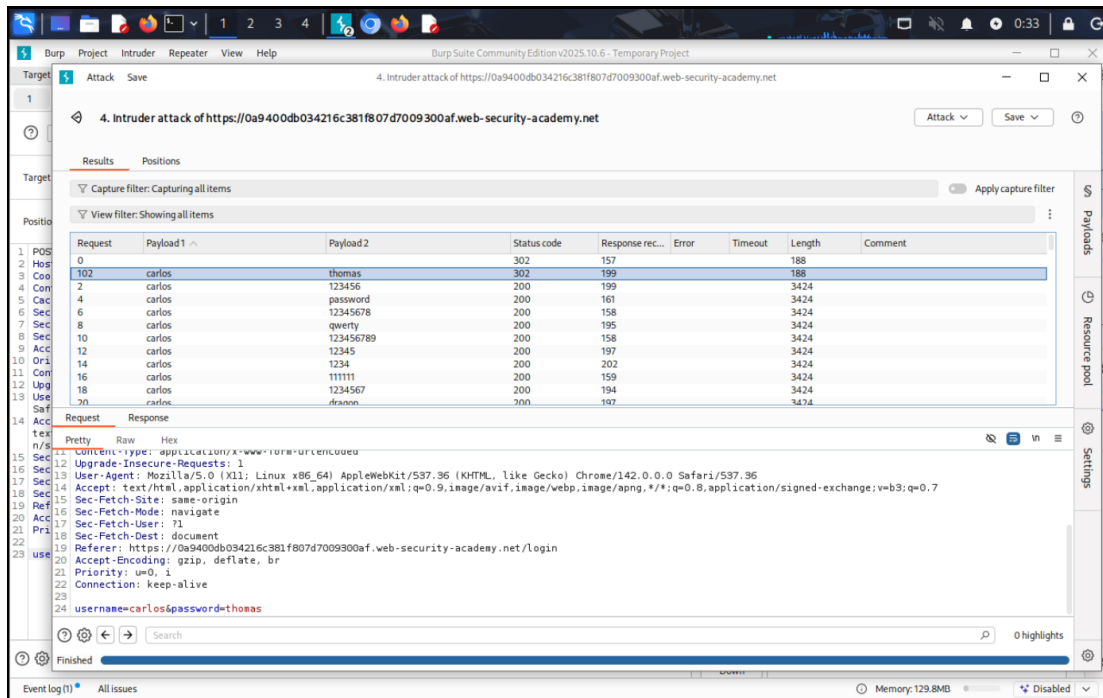


Una vez teniendo el usuario y contraseña accedemos a la cuenta

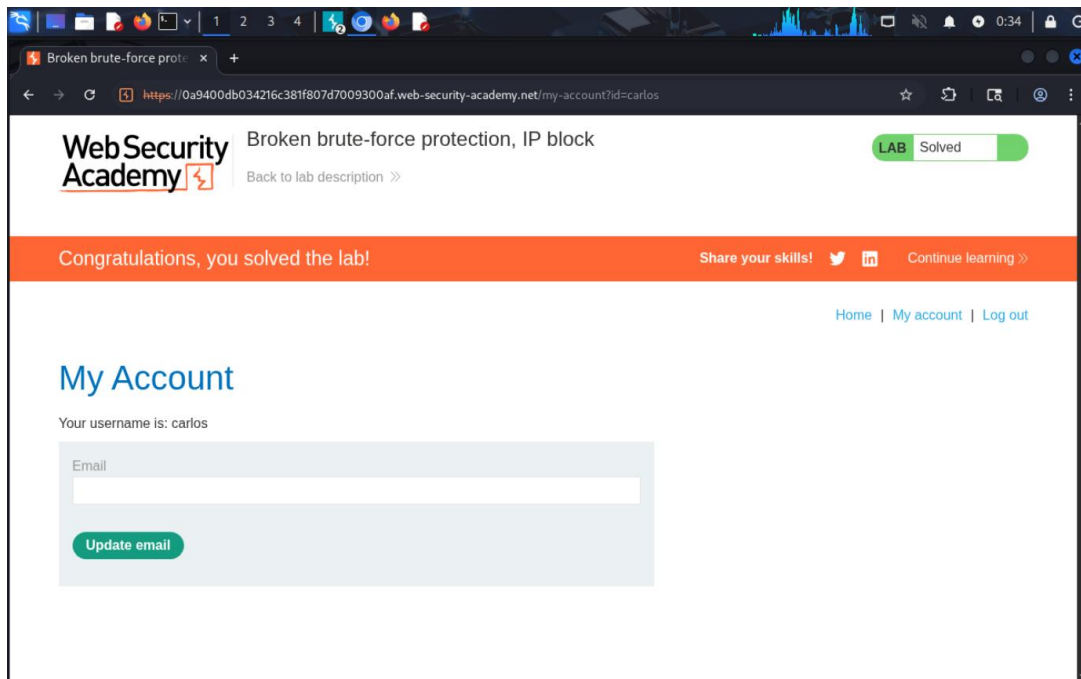
Lab: Broken brute-force protection, IP block



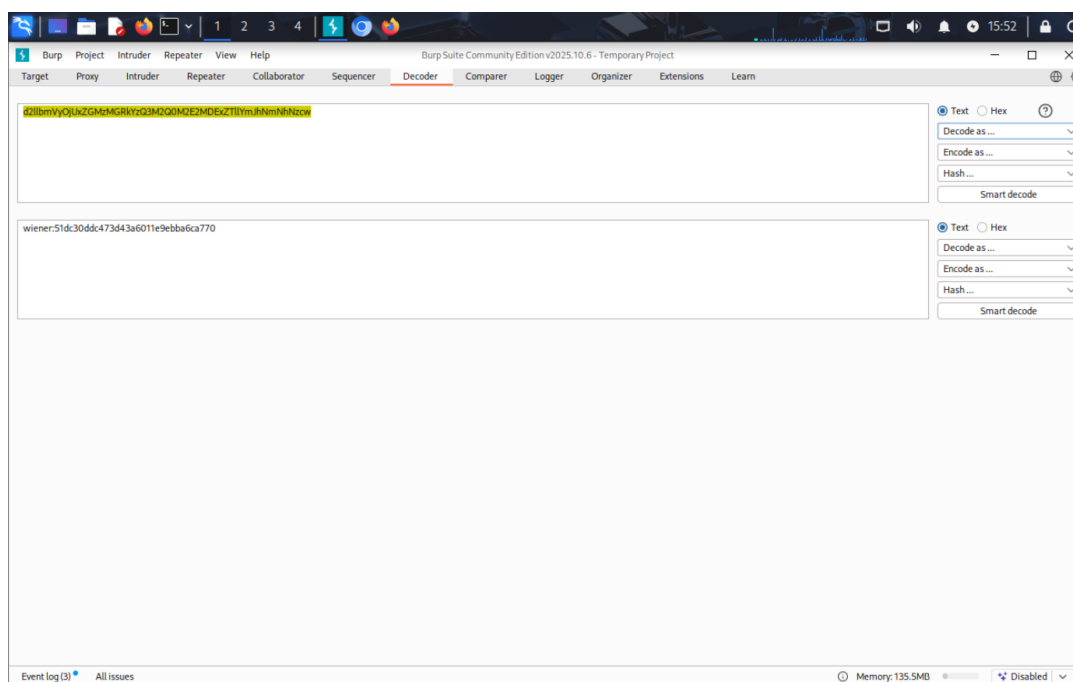
Se realiza un ataque Pitchfork que permite mandar dos listas una para cada parámetro username y password para encontrar los parámetros correctos.



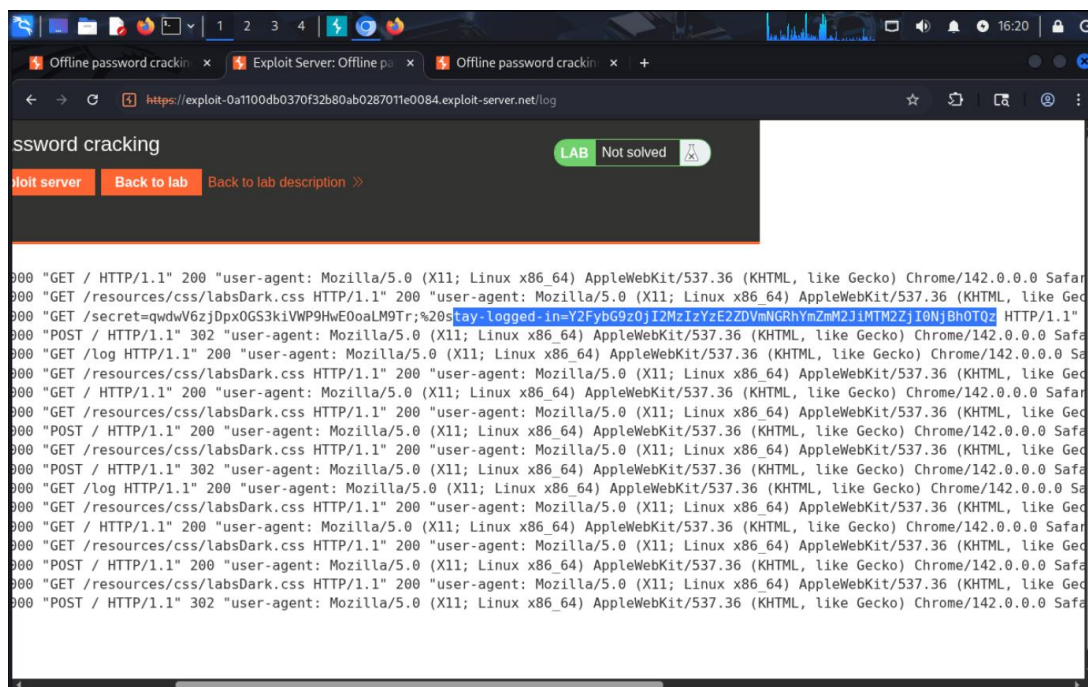
El usuario es “Carlos” y la contraseña “thomas”, con estos datos iniciamos sesión.

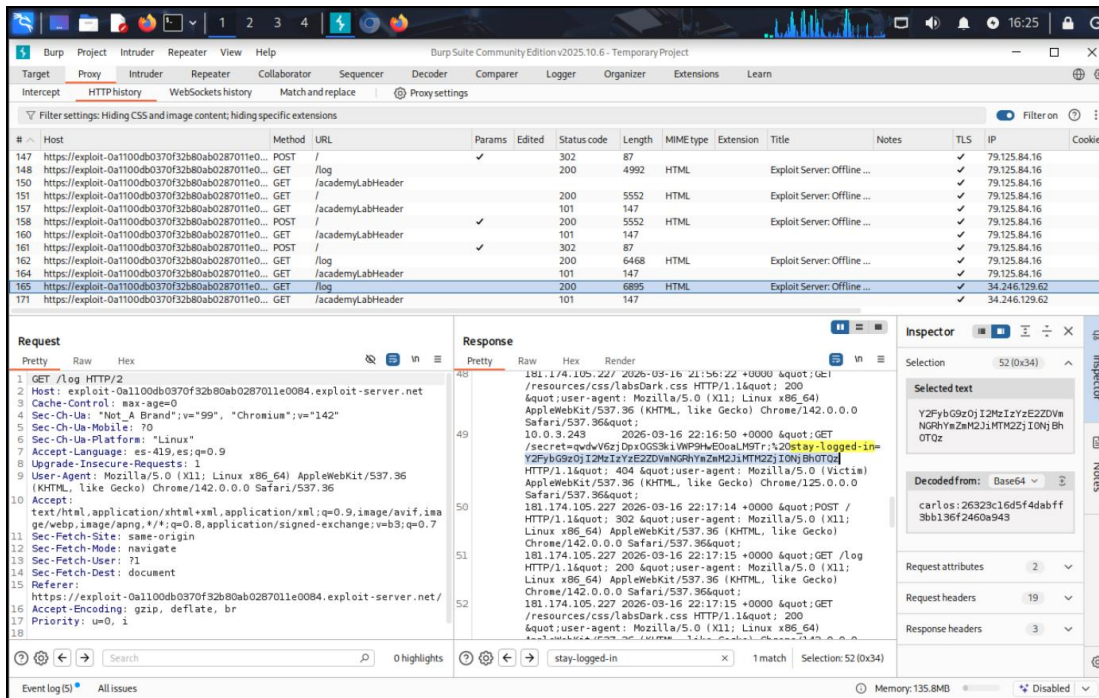


Lab: Offline password cracking

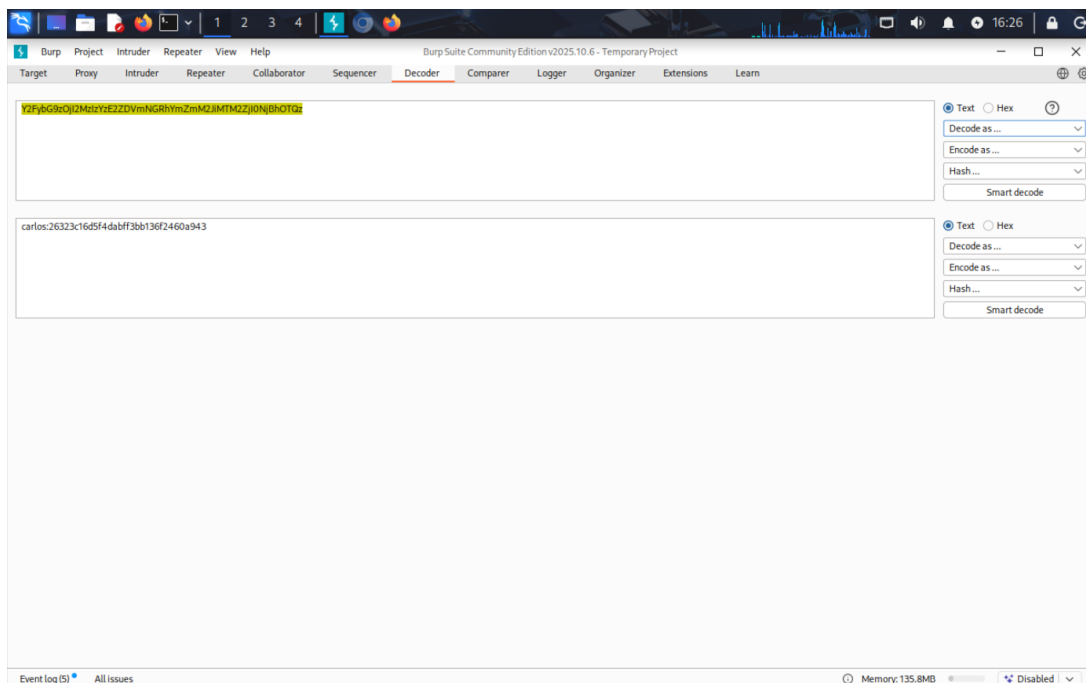


Al seleccionar “Permanecer Conectado” el stay-logged-in es un hash que con Decoder se puede descifrar y su estructura es username:+md5HashofPasword





En la pagina web al hacer un comentario debemos escribir un Payload
 “<script>....</script> “ para obtener la cookie de la victima.

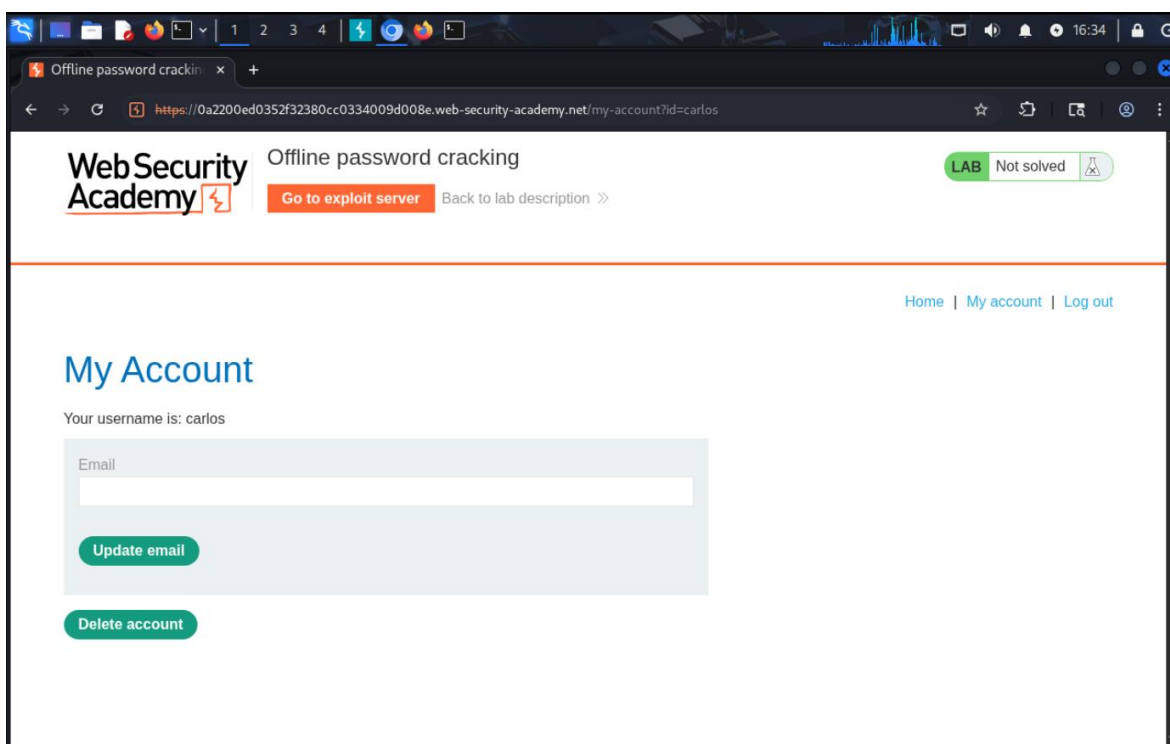


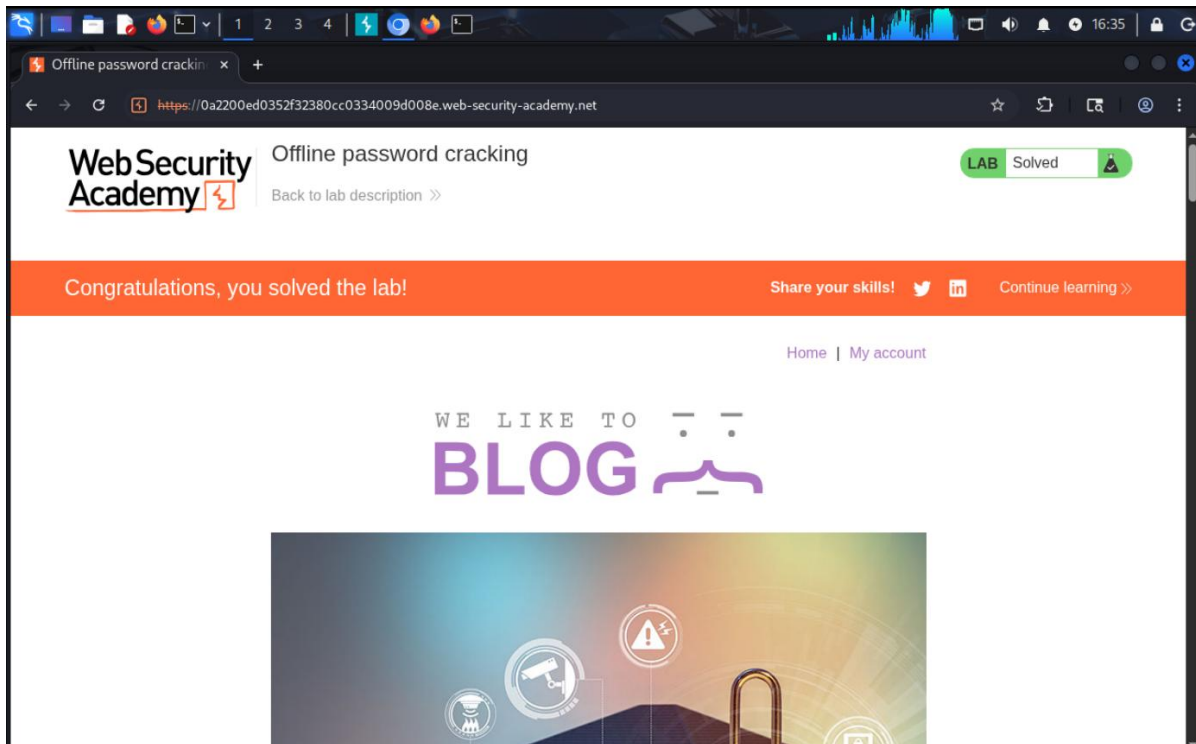
Con la opcion Decoder volvemos a procesar el hash para saber su contenido, hasta este se sabe que el usuario es Carlos.

```
(aldo@kali)-[~/Escritorio]
$ echo "26323c16d5f4dabff3bb136f2460a943" > hash.txt

(aldo@kali)-[~/Escritorio]
$ john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
onceuponatime (?)
1g 0:00:00:00 DONE (2026-03-16 16:30) 25.00g/s 2908Kp/s 2908Kc/s 2908KC/s ponting..mybaby09
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

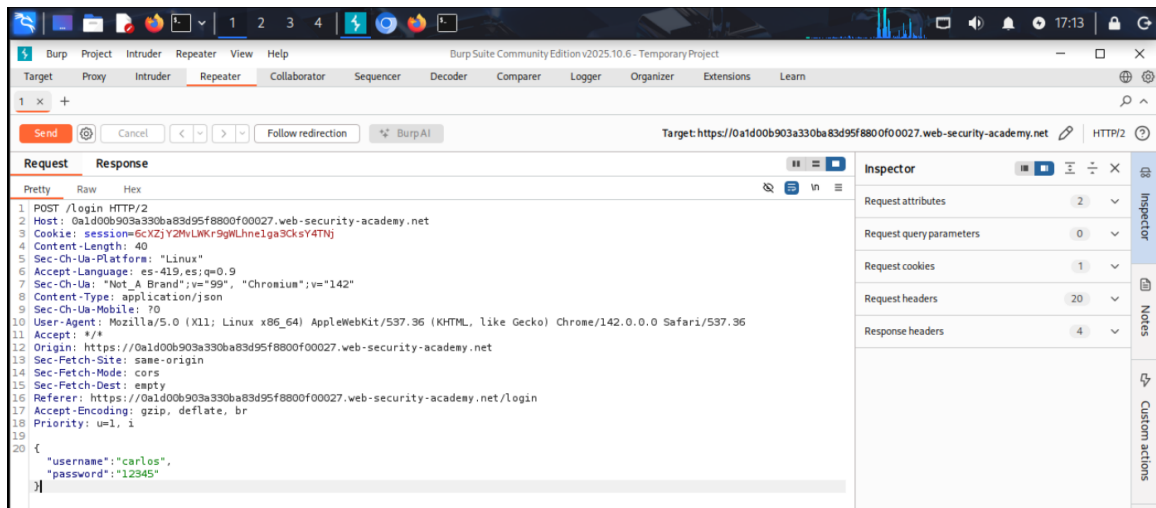
para saber la contraseña utilizamos el comando john para poder averiguar la contraseña con el hash que nos dieron.



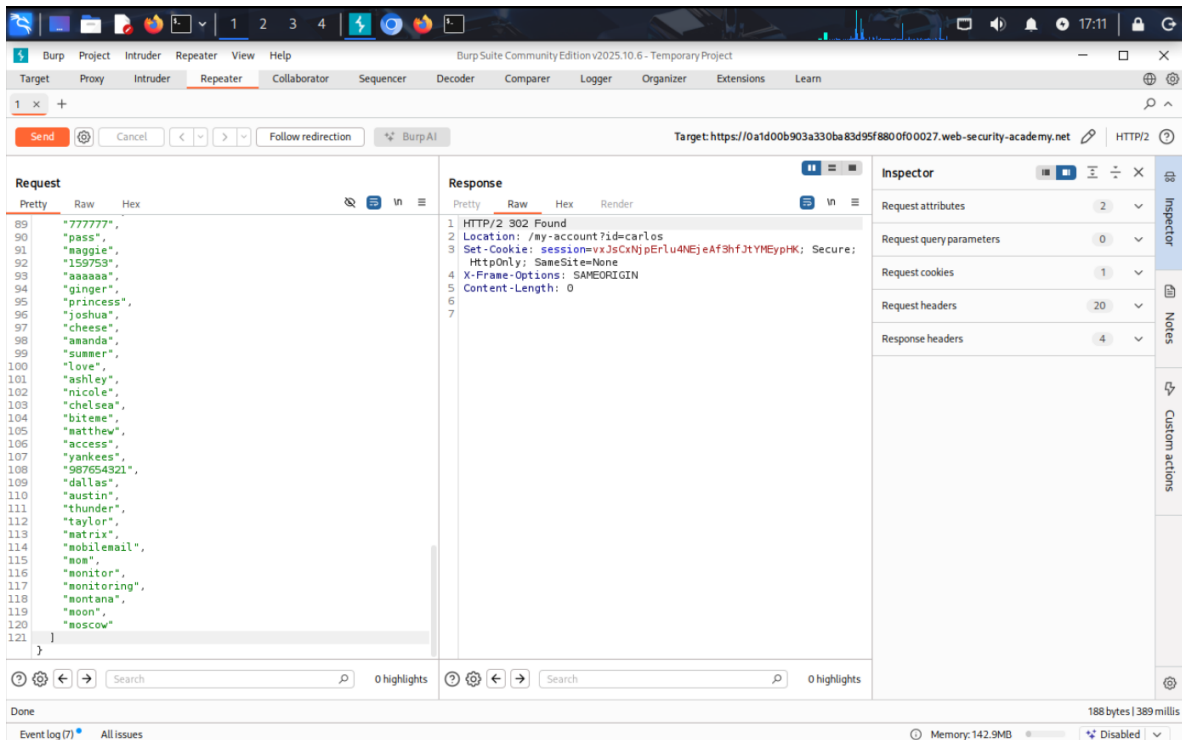


Una vez dentro de la cuenta de Carlos, se debe eliminar la cuenta.

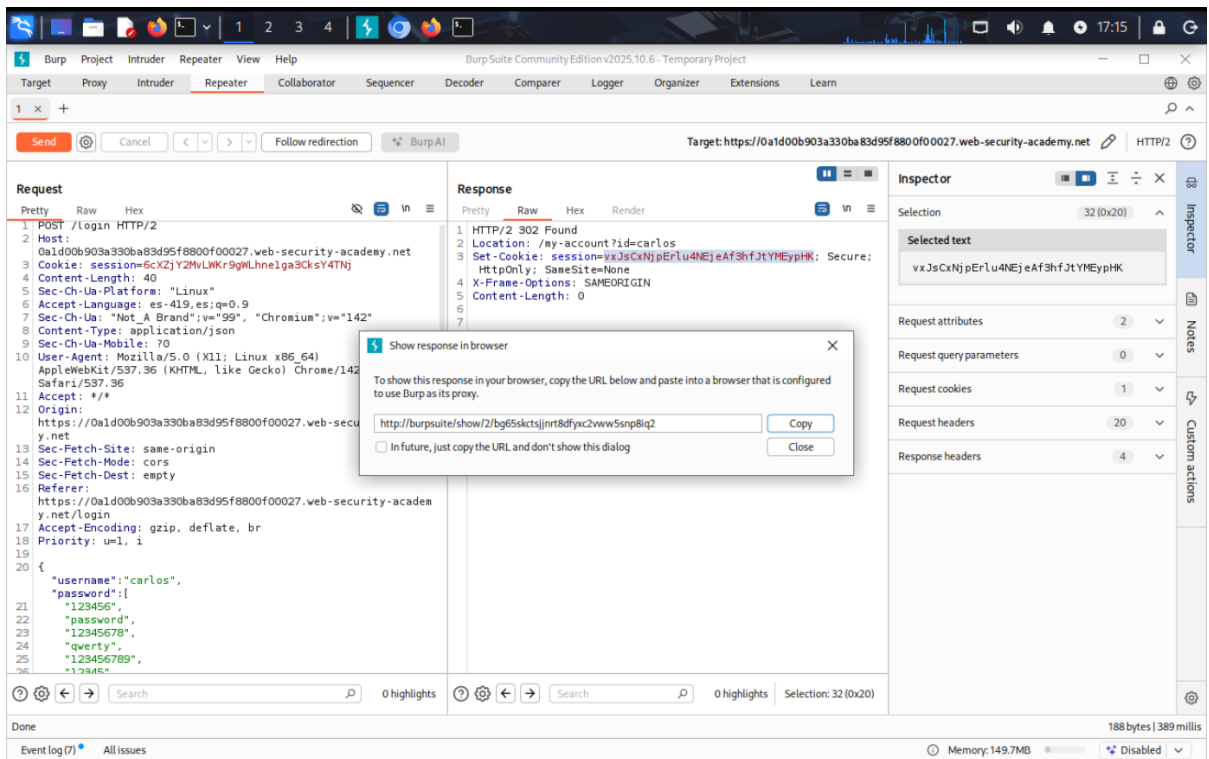
Lab: Broken brute-force protection, multiple credentials per request



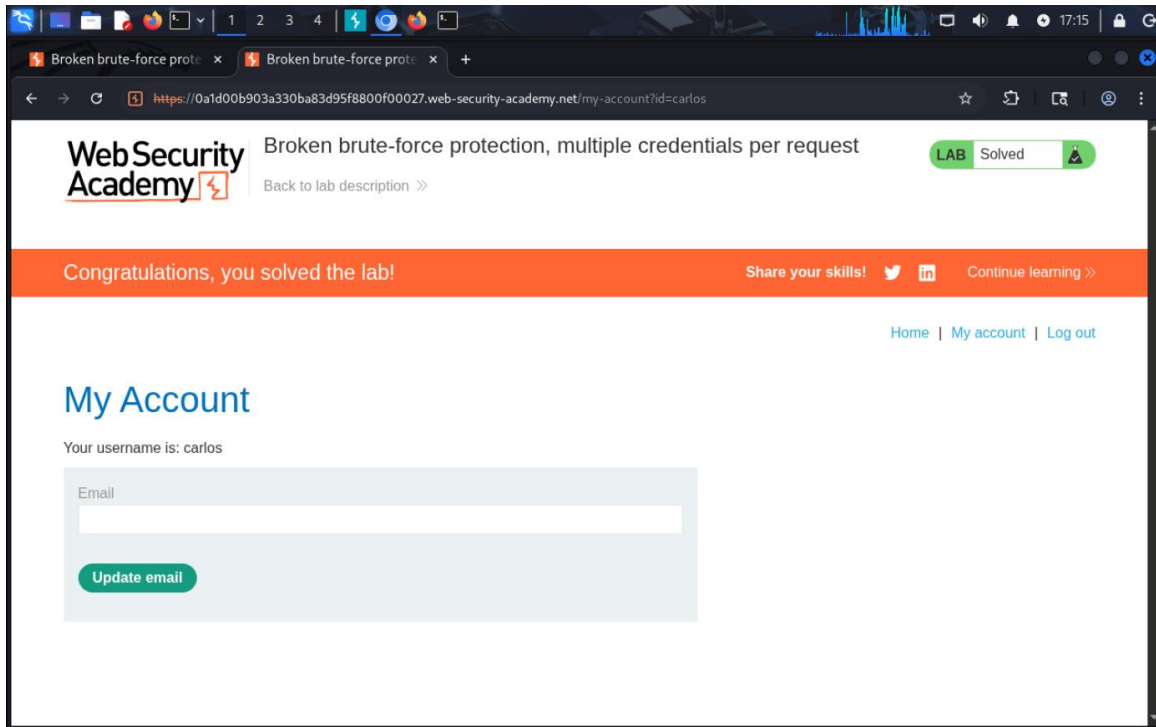
Hay que tener en cuenta que la usuario y contraseña se muestran en formato JSON



Ahora reemplazamos el valor de password por un array que contiene todas las contraseñas posibles.

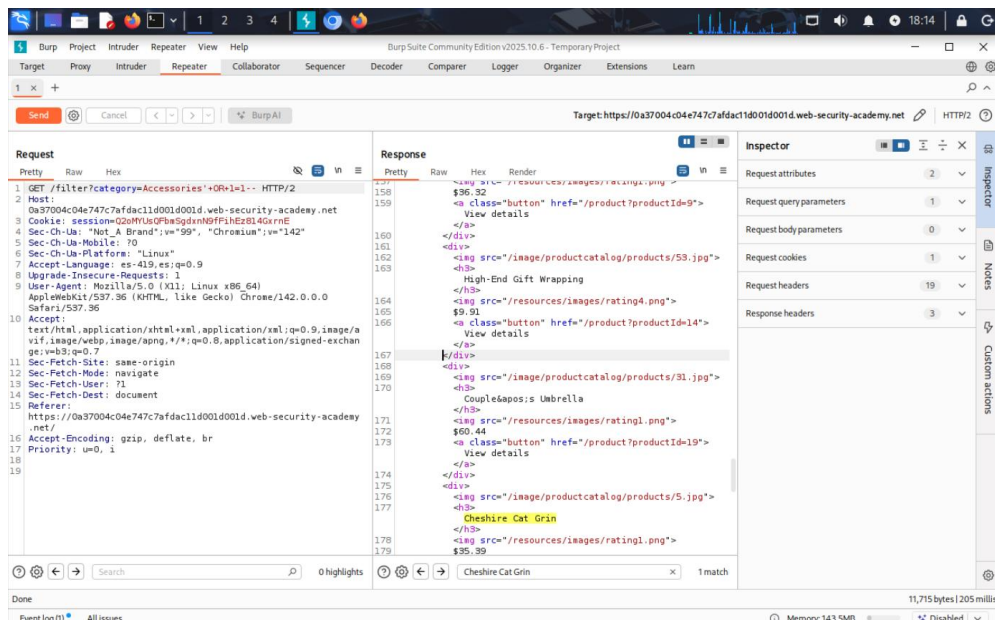


Con la opción “Show response in browser” podemos ver con nos da el valor de “session”

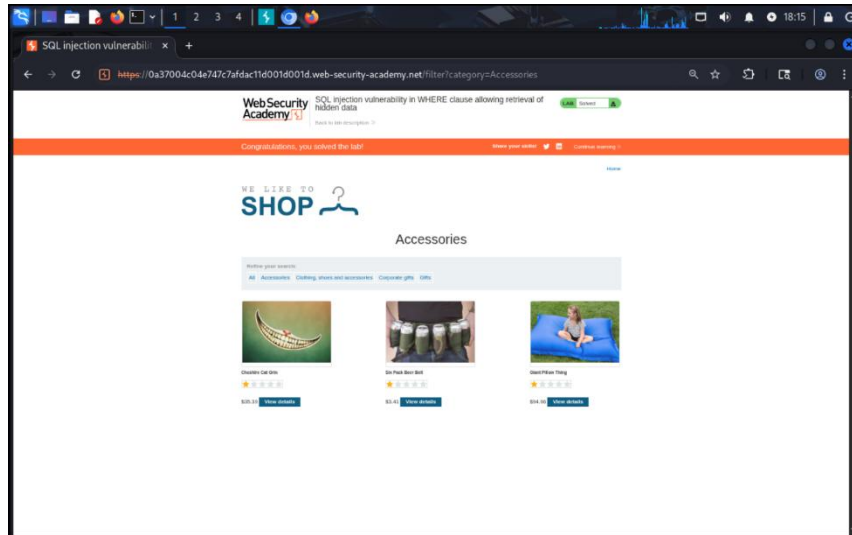


SQL Injection

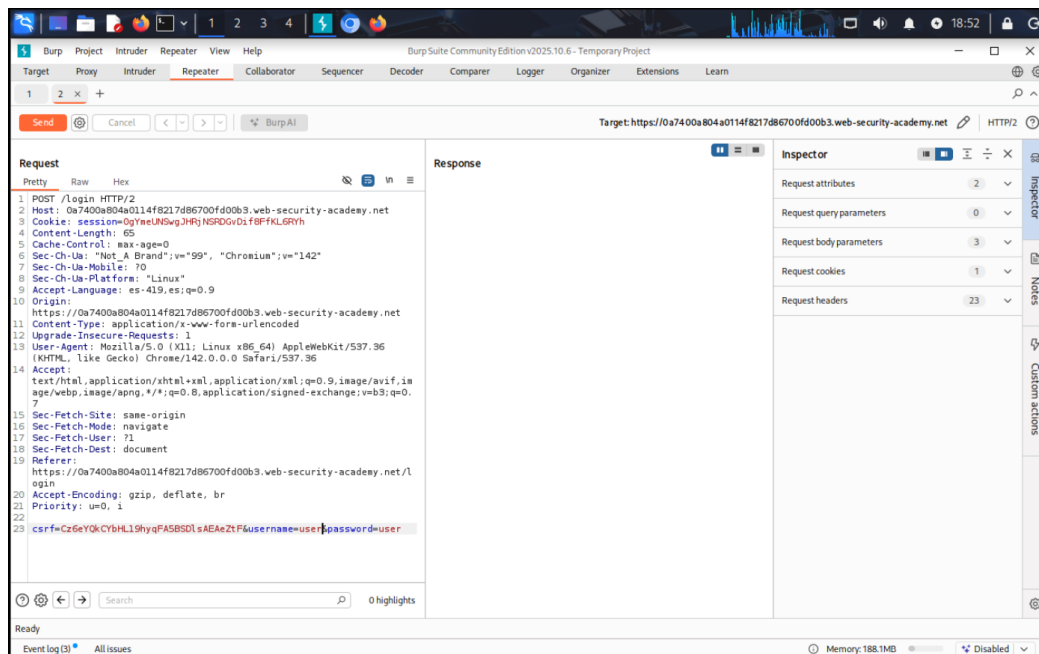
Lab: SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

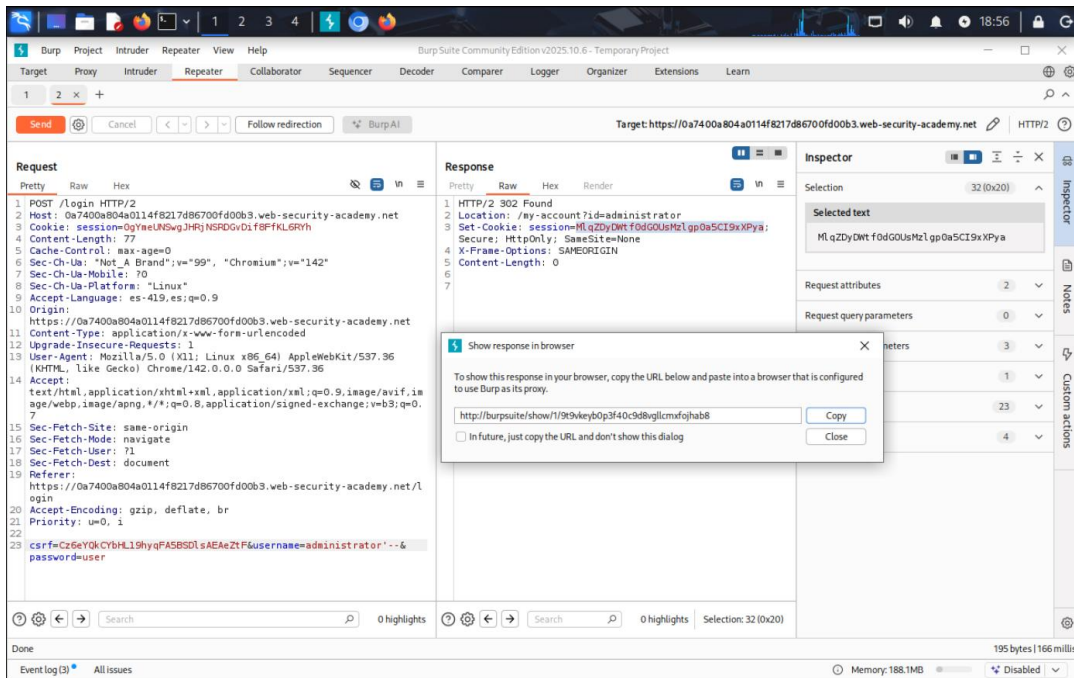


El valor de “category” se debe modificar para ver que hay mas de un producto.

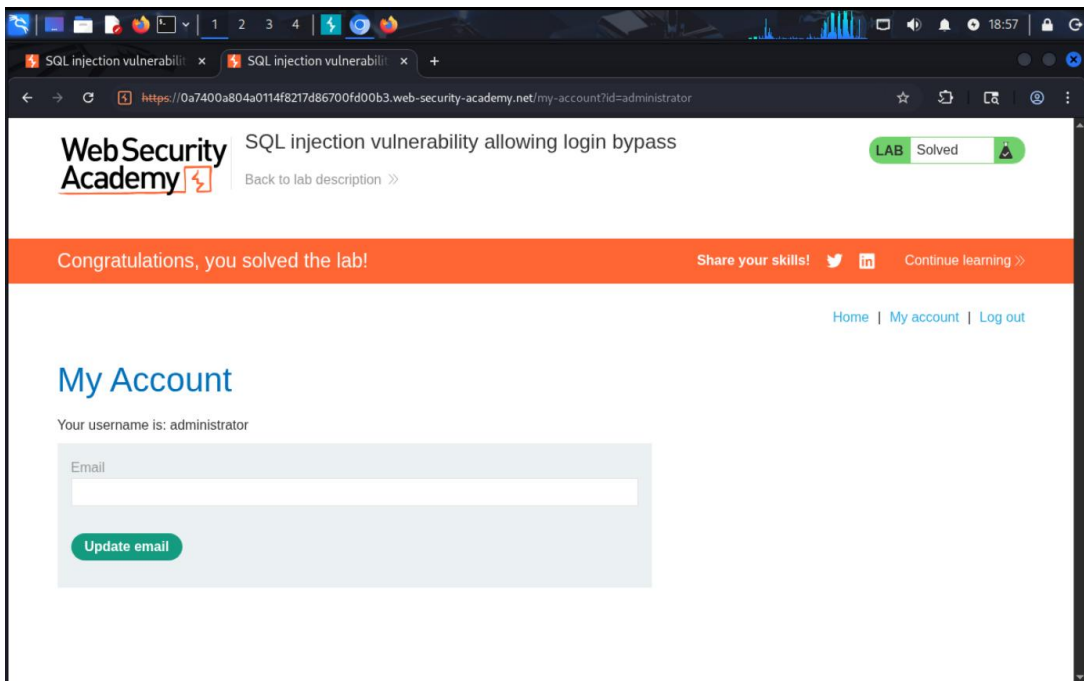


Lab: SQL injection vulnerability allowing login bypass



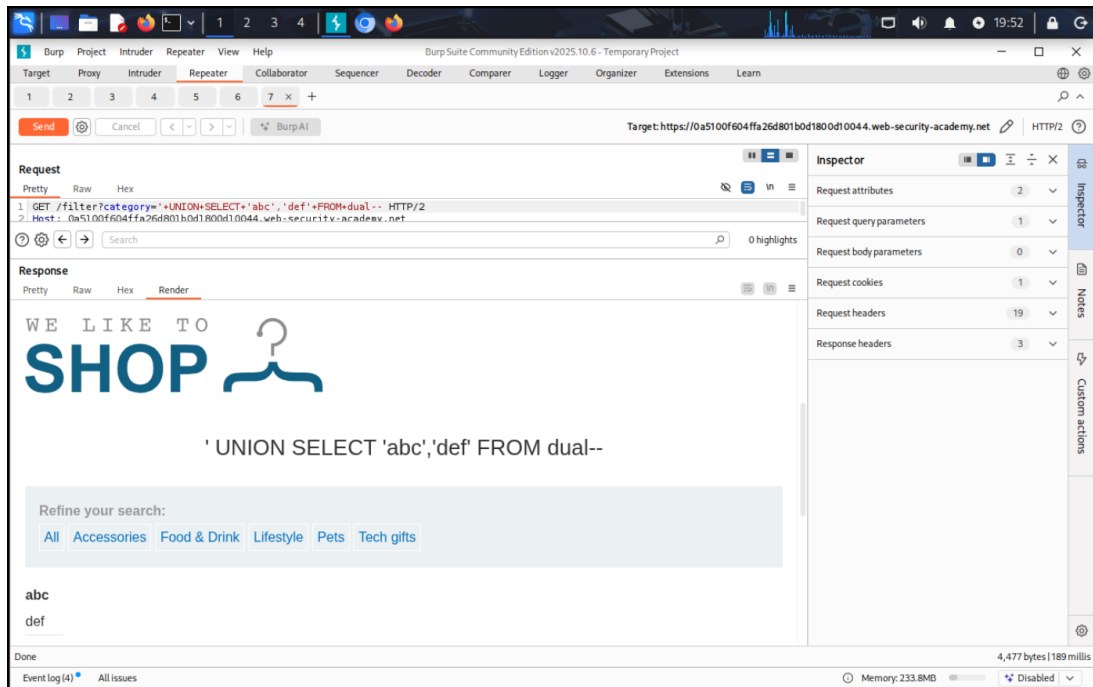


El valor del campo “username” se cambia por “administrator--”

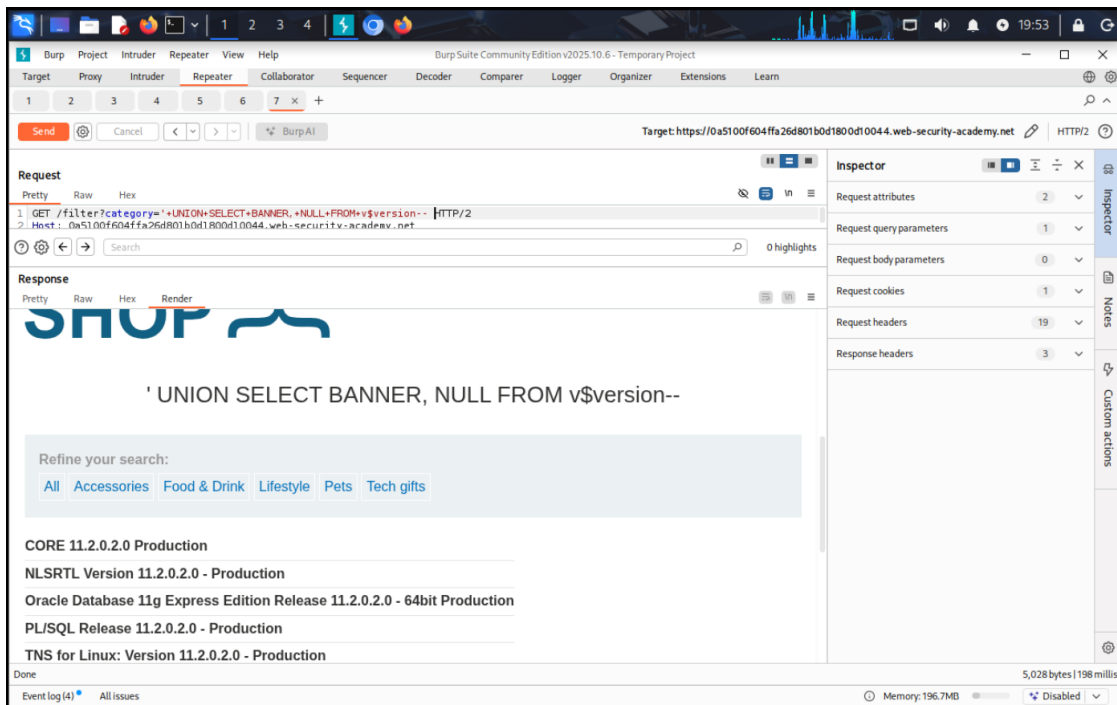


con lo que se hizo anteriormente iniciamos sesión.

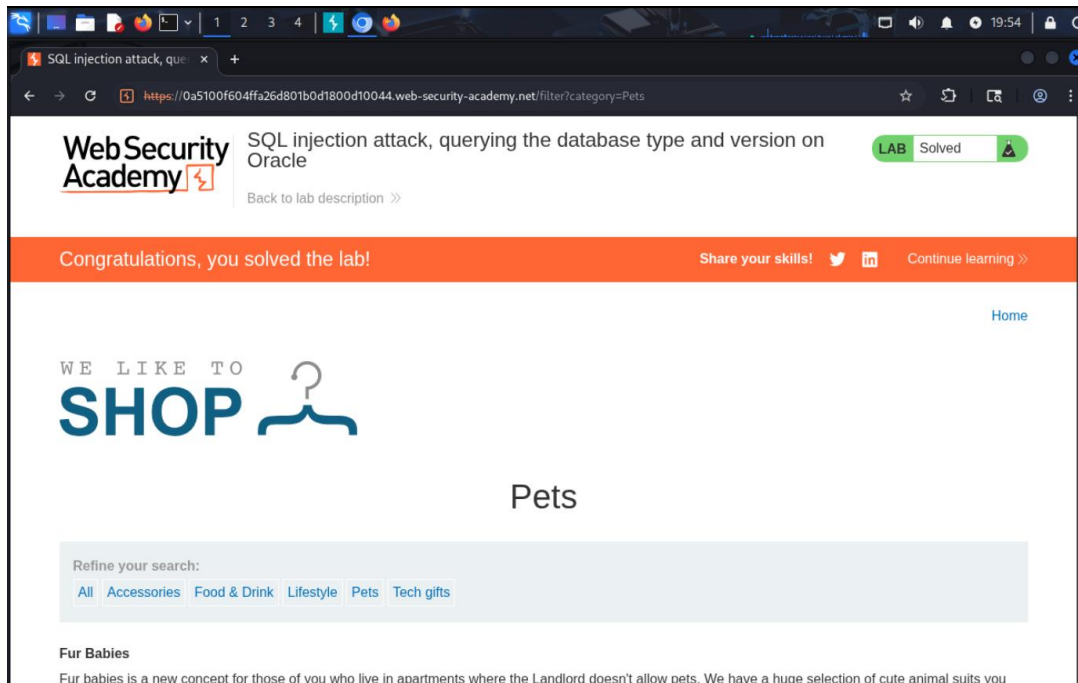
Lab: SQL injection attack, querying the database type and version on Oracle



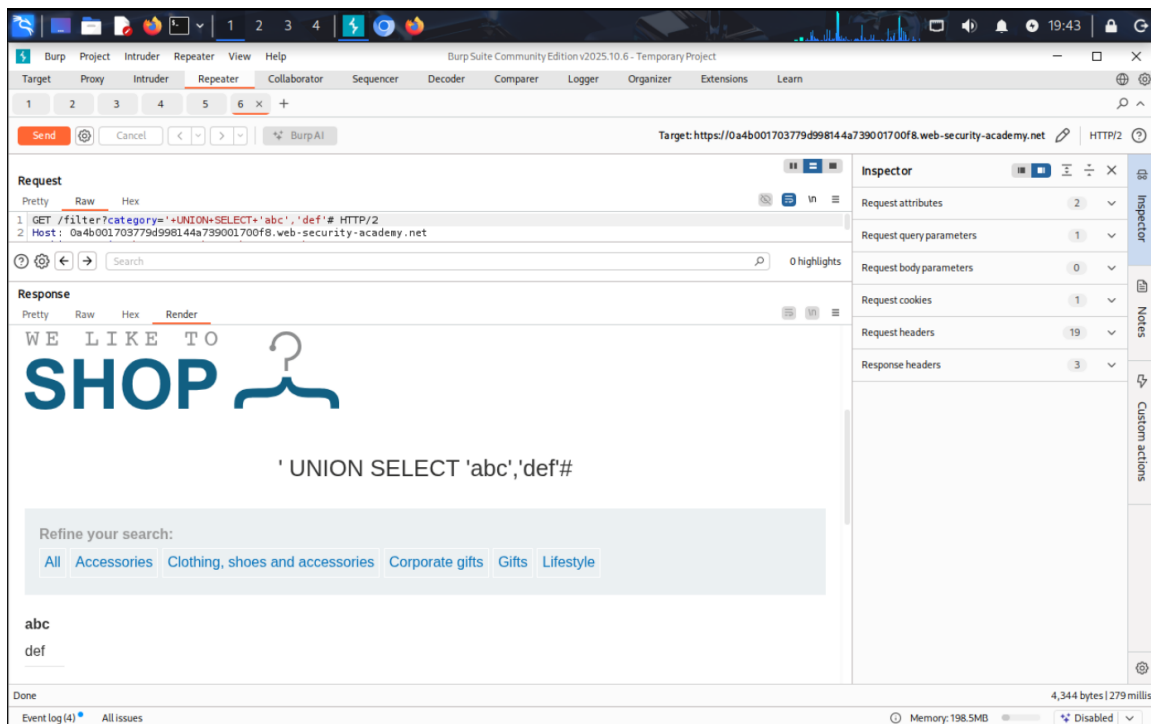
Se debe modificar el valor de “category” para saber cuantas columnas existen.



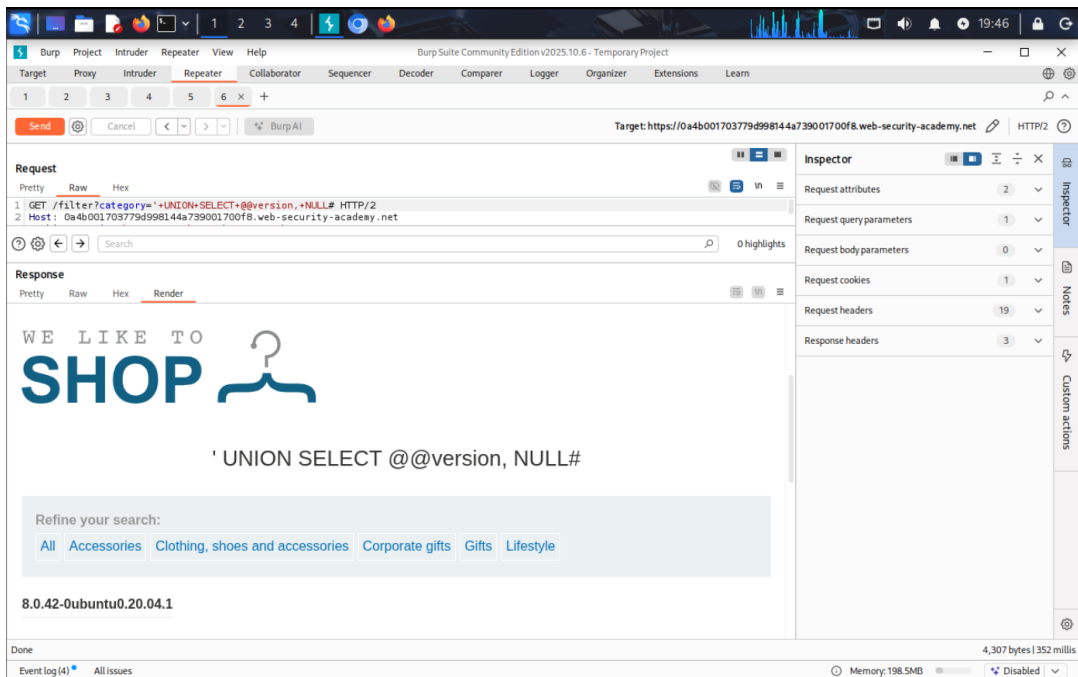
Se modifica nuevamente “category” para poder ver la versión de la base de datos.



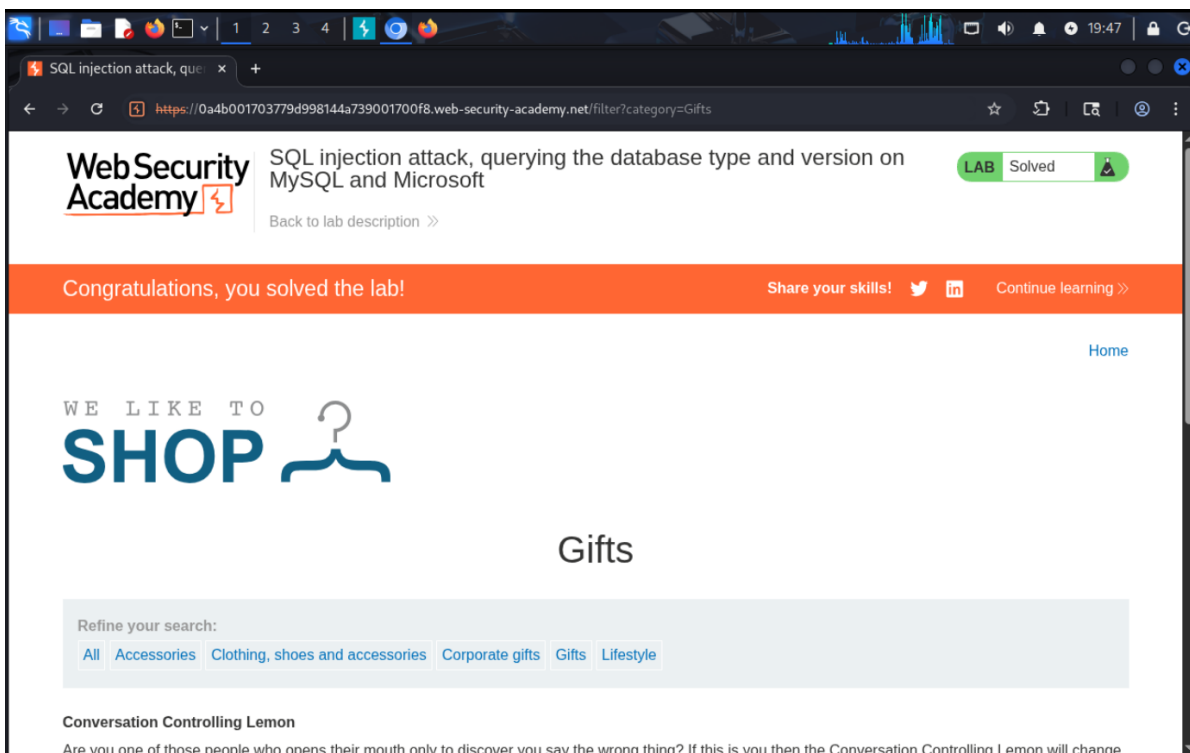
Lab: SQL injection attack, querying the database type and version on MySQL and Microsoft



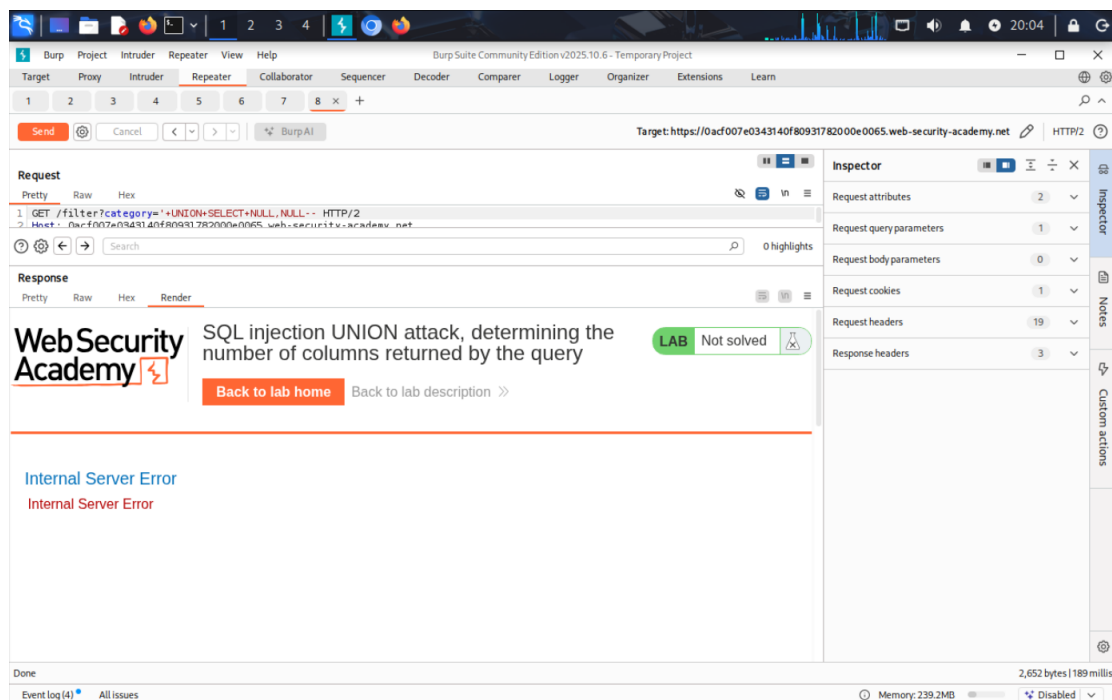
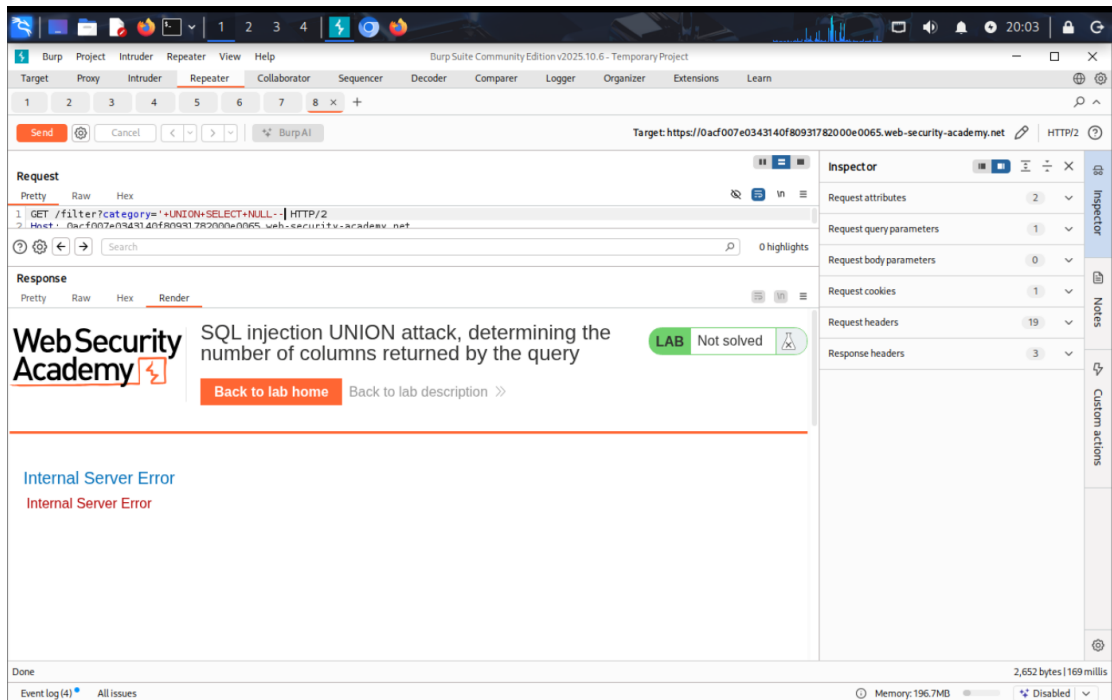
Se debe modificar el valor de “category” para saber cuantas columnas existen.



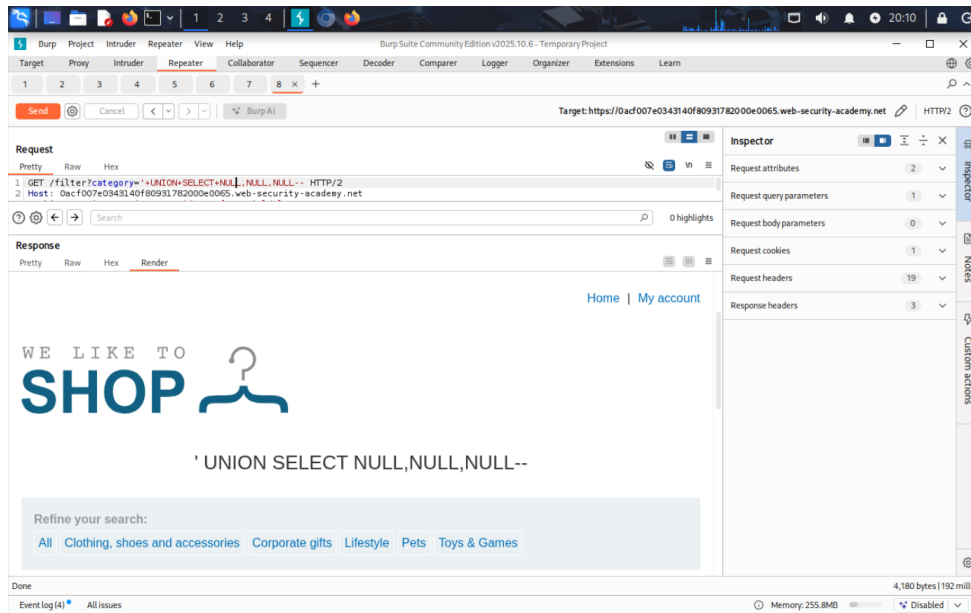
Se modifica nuevamente “category” para poder ver la versión de la base de datos



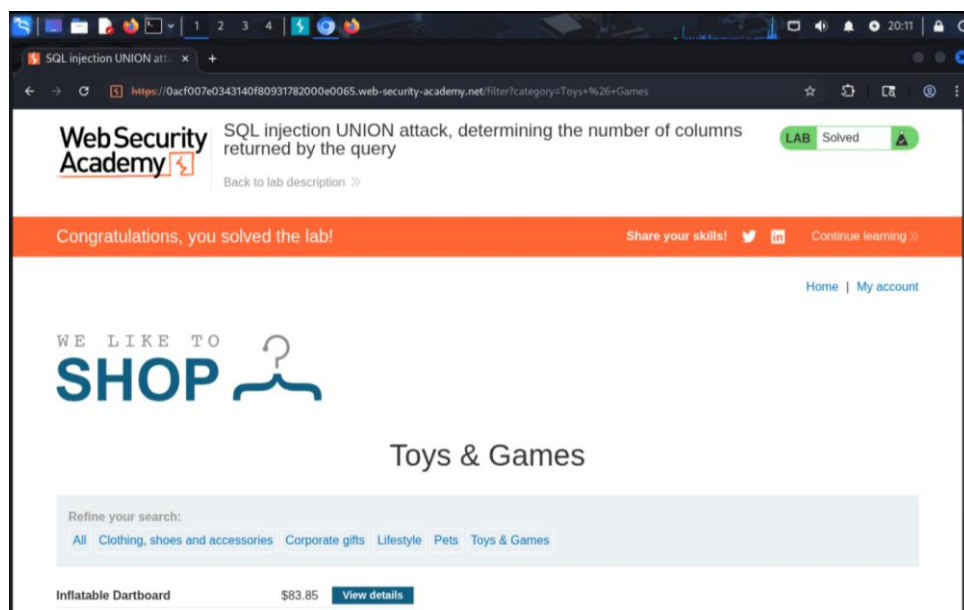
Lab: SQL injection UNION attack, determining the number of columns returned by the query



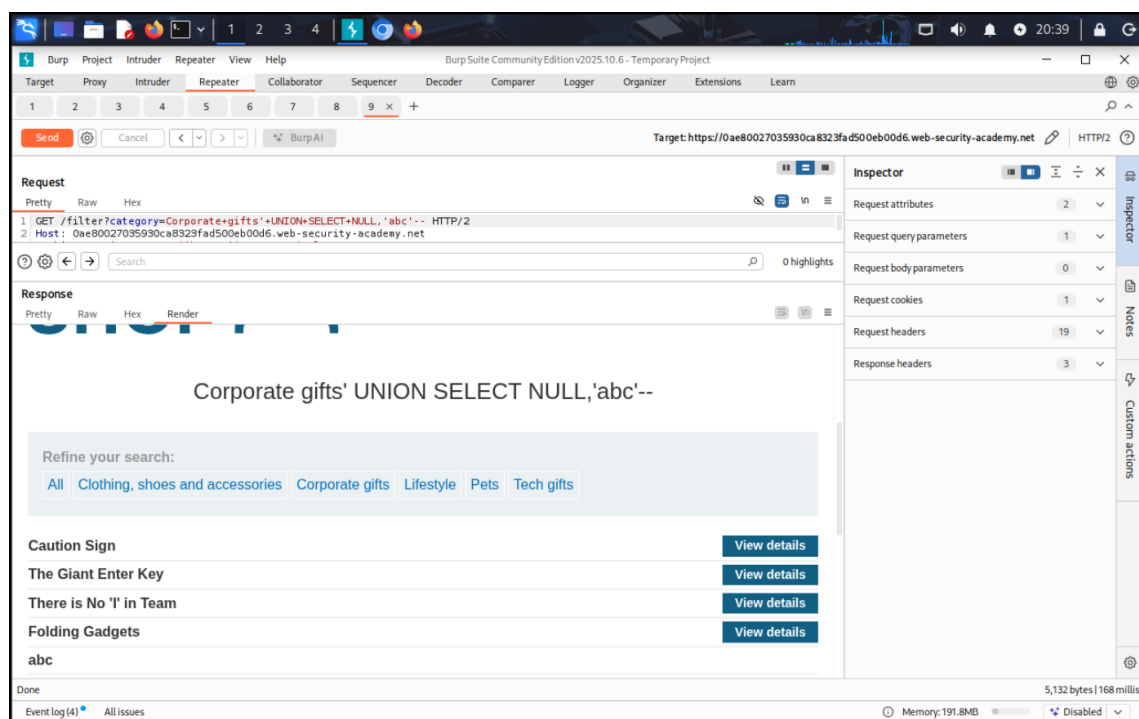
La pagina muestra error porque no se muestran todas las columnas que existen.



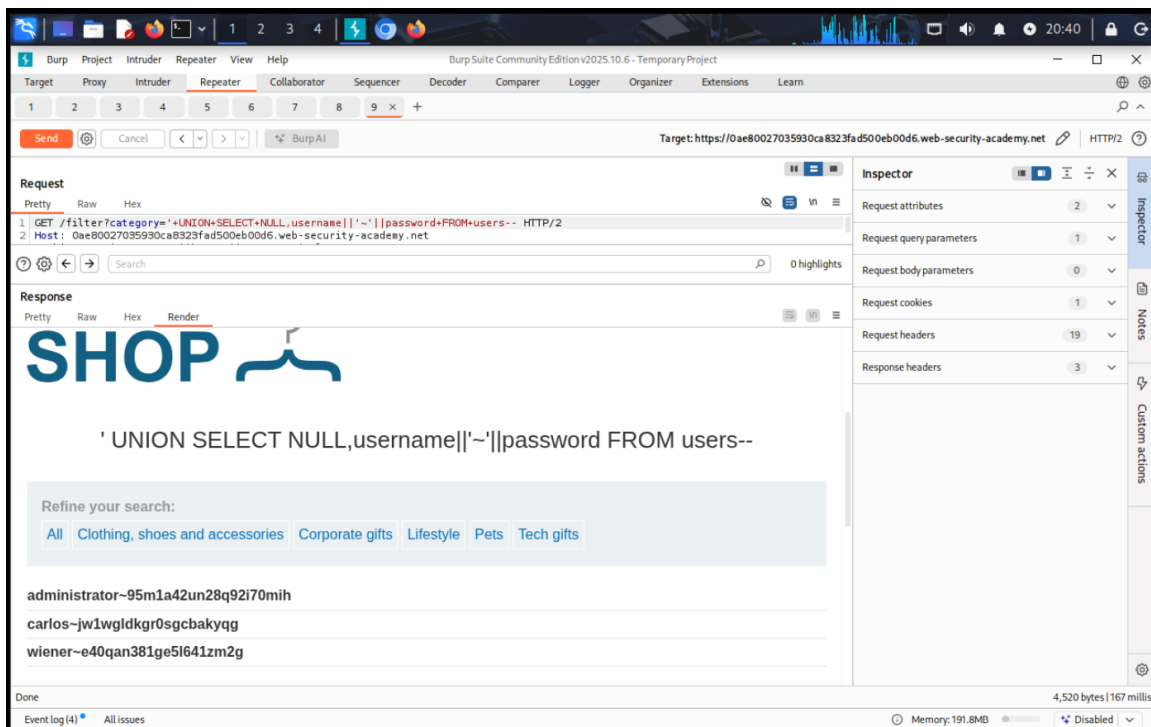
Para dejar de ver el error es necesario ir agregando NULL al valor del parámetro “Category”



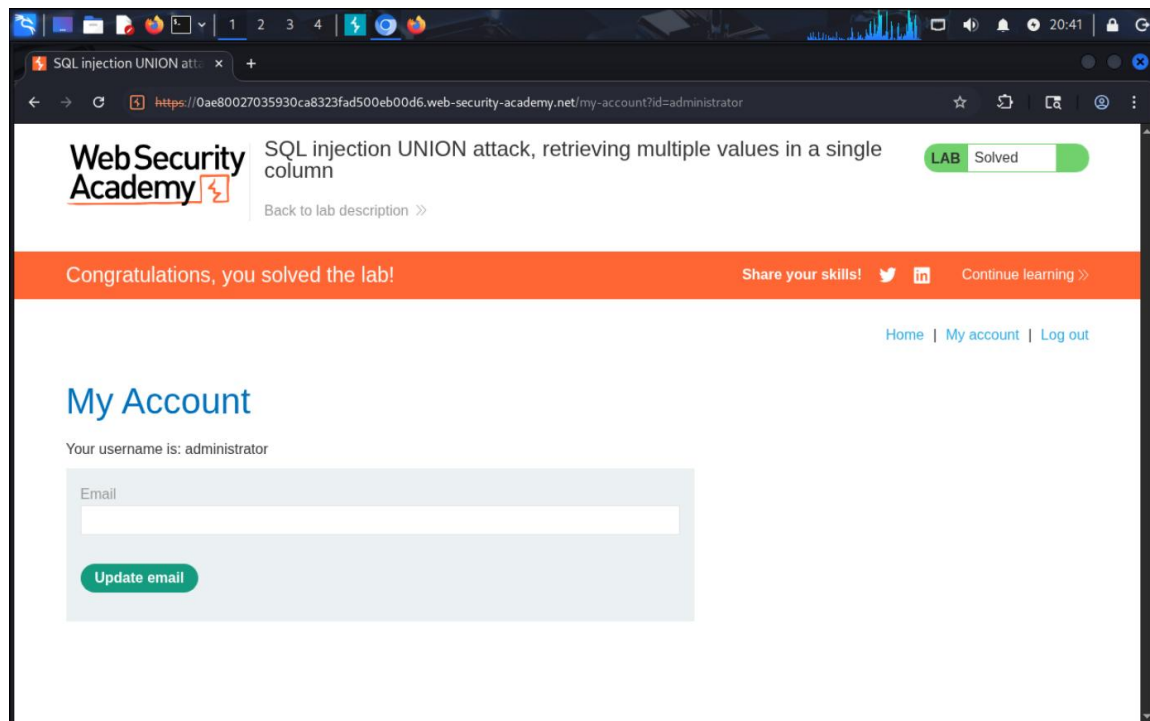
Lab: SQL injection UNION attack, retrieving multiple values in a single column



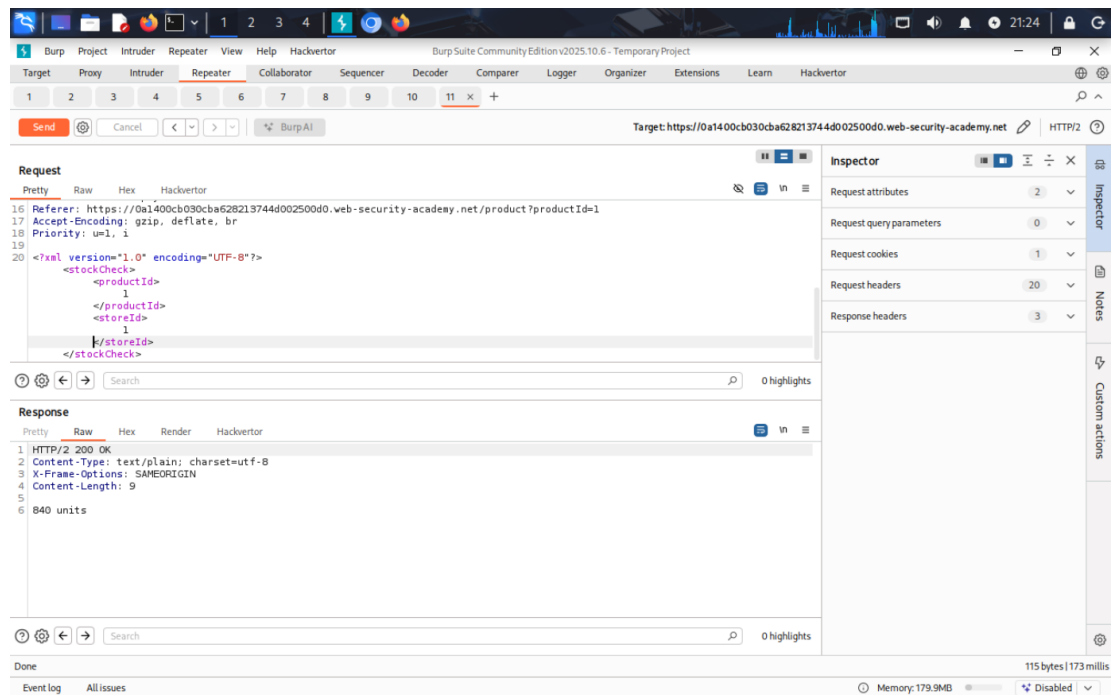
La pagina muestra error porque no se muestran todas las columnas que existen.

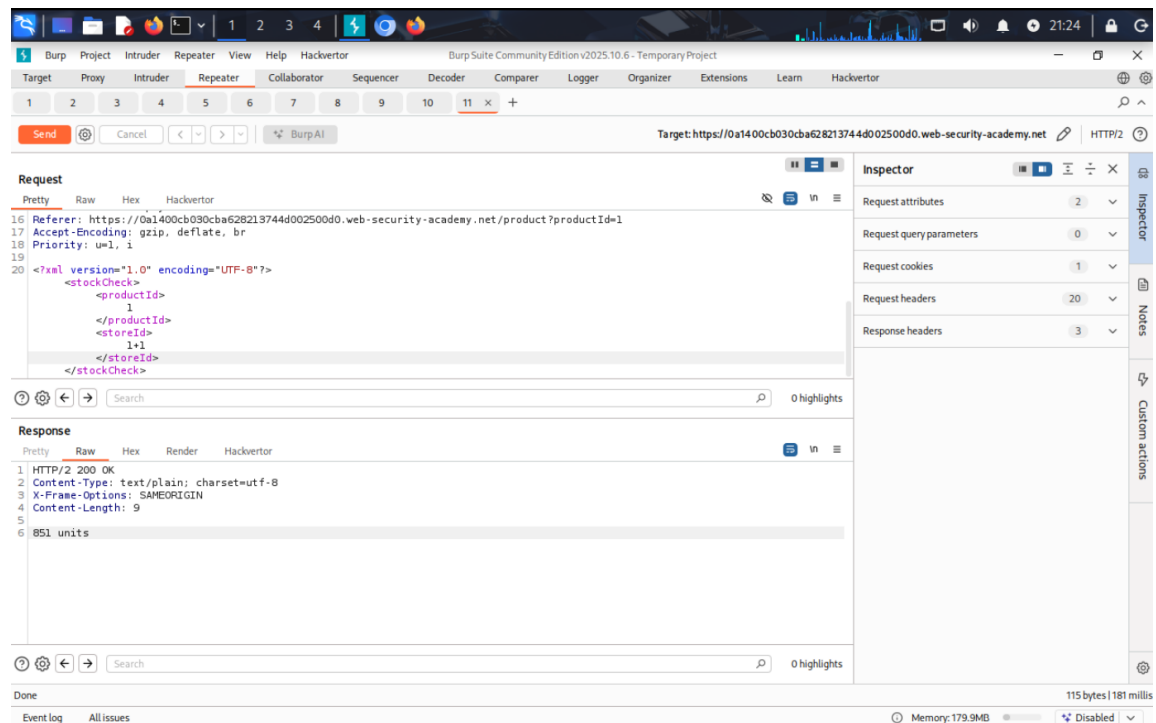


Se modifica el valor de category para poder ver los usuarios y contraseñas

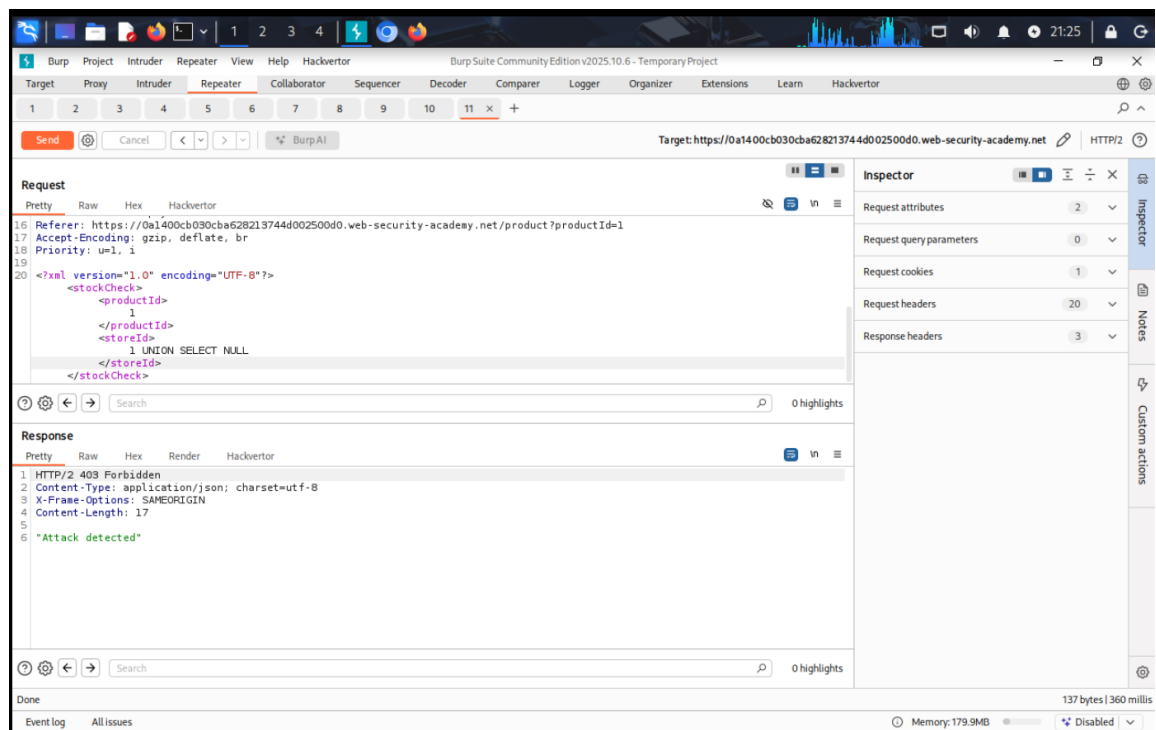


Lab: SQL injection with filter bypass via XML encoding

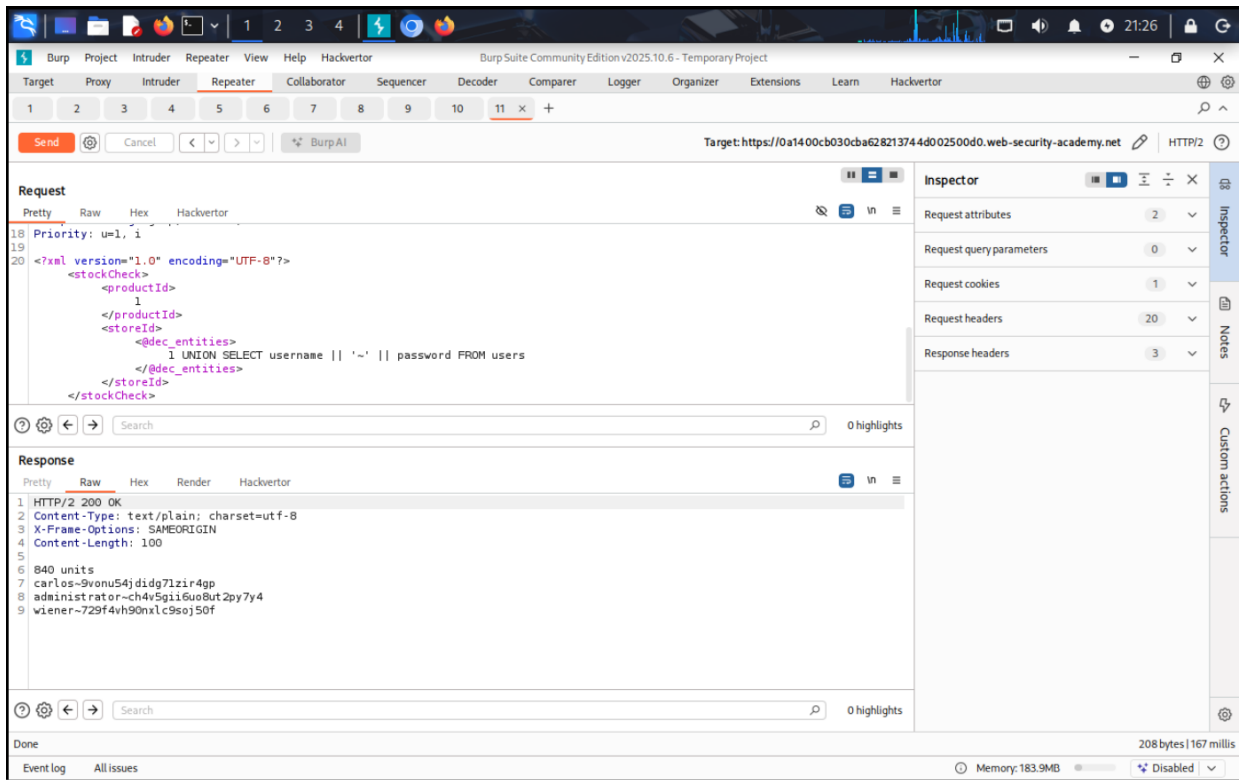




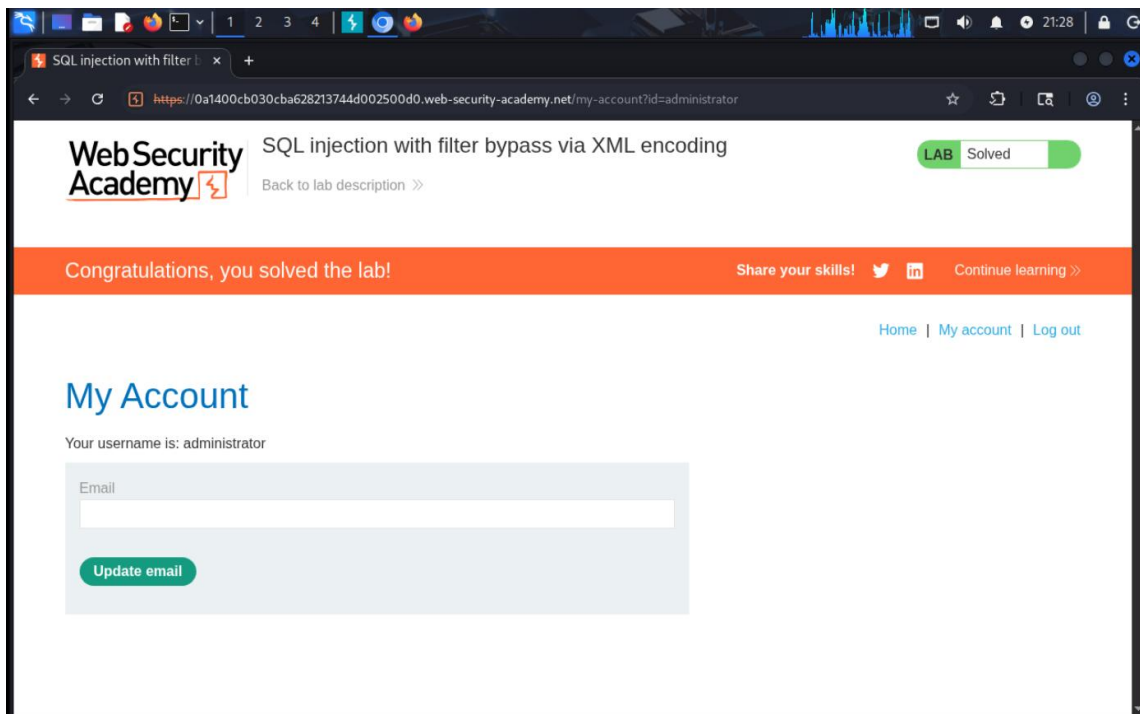
Se modifco el contenido de “storeId” y se puede notar que las unidades cambian si se cambia este valor



Se modifica “storeId” para ver el número de columnas, pero somos bloqueados



Para evitar este bloqueo usamos la opción de dec_entities que se encuentra en la extension Hackvertor



Para finalizar iniciamos sesión con las credenciales correctas.